CRISC Exam - Hard Questions with Explanations

From ISACA CRISC QAE Manual 6th Edition

Compiled from ISACA CRISC Q&A

October 25, 2026

Outline

1. Domain 1: Governance
2. Domain 2: IT Risk Assessment
3. Domain 3: Risk Response
4. Domain 4: Information Technology and Security

Q1: Risk Management Strategy

Question

Which is MOST important to determine when defining risk management strategies?

A. Risk assessment criteria
B. IT architecture complexity
C. Enterprise disaster recovery plan
D. Business objectives and operations

Q1: Explanation

Correct Answer: D

While defining risk management strategies, the risk practitioner needs to analyze the enterprise's objectives and risk tolerance and define a risk management framework based on this analysis.

Option Analysis

- **A - Incorrect:** Risk assessment criteria alone are not sufficient
- **B - Incorrect:** IT architecture complexity is more related to assessing risk than defining strategies
- **C - Incorrect:** DR plan is more related to mitigating risk
- **D - Correct:** Business objectives drive risk management strategy

Q2: Risk Management Strategic Plan

Question

Which is MOST important to include in a risk management strategic plan?

- A Risk management staffing requirements
- B Risk management mission statement
- C Risk mitigation investment plans
- D Current state and desired future state

Q2: Explanation

Correct Answer: D

It is most important to paint a vision for the future and then draw a road map from the starting point, which requires that the current state and desired future state be fully understood.

Option Analysis

- **A - Incorrect:** Staffing requirements are driven by understanding current/future state
- **B - Incorrect:** Mission statement is important but not actionable
- **C - Incorrect:** Investment plans are driven by current/future state
- **D - Correct:** Understanding current and desired state is foundational

Q3: BU Risk Roles

Question

Which BEST describes risk-related roles of an organizational business unit?

- A BU management owns mitigation plan; board identifies risk
- B BU management owns risk and is responsible for identifying, assessing and mitigating risk
- C BU carries out responsibilities; ultimate accountability belongs to board
- D BU is ultimately accountable; board owns the risk

Q3: Explanation

Correct Answer: B

The BU is responsible for owning the risk and its resulting actions. Risk owners have the responsibility of identifying, measuring, monitoring, controlling and reporting on risk.

Option Analysis

- **A - Incorrect:** Board does not perform identification/assessment
- **B - Correct:** BU owns risk and all associated activities
- **C - Incorrect:** BU also has accountability for day-to-day work
- **D - Incorrect:** Board does not own BU risk

Q4: Outsourcing Security Consideration

Question

Enterprise outsourced IT to a third party whose servers are in a foreign country. Which is MOST critical security consideration?

- A Security breach notification may be delayed due to time difference
- B Additional network intrusion detection sensors needed
- C Enterprise could be unable to monitor compliance with internal guidelines
- D Laws of country of origin may not be enforceable in foreign country

Q4: Explanation

Correct Answer: D

Laws and regulations of the country of origin may not be enforceable in the foreign country. Conversely, the laws of the foreign vendor may also affect the enterprise.

Option Analysis

- **A - Incorrect:** Time difference does not affect 24/7 environments
- **B - Incorrect:** Additional sensors are manageable
- **C - Incorrect:** Outsourcing does not remove internal responsibility
- **D - Correct:** Legal enforceability across borders is critical

Q5: Risk Management Process Improvement

Question

Which is MOST beneficial to improvement of an enterprise's risk management process?

A. Key risk indicators
B. External benchmarking
C. Latest risk assessment
D. A maturity model

Q5: Explanation

Correct Answer: D

A maturity model helps identify the status quo and the path to get to the enterprise's desired state and thus is most helpful when an enterprise desires to improve a business process.

Option Analysis

- **A - Incorrect:** KRIs help monitor but don't define desired state
- **B - Incorrect:** Benchmarking helps compare but doesn't define path
- **C - Incorrect:** Risk assessment is an input, not a path to improvement
- **D - Correct:** Maturity model provides current state and path to desired state

Q6: Independent Risk Review

Question

Which is PRIMARY reason for subjecting risk management process to review by independent risk auditors?

A. To ensure risk results are consistent
B. To ensure risk factors and risk profile are well-defined
C. To correct any mistakes in risk assessment
D. To validate control weaknesses for management reporting

Q6: Explanation

Correct Answer: B

Risk profile and risk factors are defined during the risk assessment process; an independent review helps ensure that the underlying process is effective and helps identify areas for future improvement.

Option Analysis

- **A - Incorrect:** Consistency is important but not primary
- **B - Correct:** Independent review validates the process
- **C - Incorrect:** Primary purpose is process improvement, not correction
- **D - Incorrect:** Validating weaknesses may be an outcome but not primary

Q7: Evaluating Legal Requirements Impact

Question

What is MOST effective method to evaluate potential impact of legal, regulatory and contractual requirements on business objectives?

A. Compliance-oriented gap analysis

B. Interviews with business process stakeholders

C. Mapping compliance requirements to policies

D. Compliance-oriented business impact analysis

Q7: Explanation

Correct Answer: D

A compliance-oriented business impact analysis will identify compliance requirements to which the enterprise is subject and will assess their effect on business objectives and activities.

Option Analysis

- **A - Incorrect:** Gap analysis only identifies gaps, not business impact
- **B - Incorrect:** Interviews identify objectives but not compliance impact
- **C - Incorrect:** Mapping shows how compliance is achieved, not impact
- **D - Correct:** Compliance BIA assesses effect on business objectives

Q8: Risk Assessment RFP

Question

When hiring consultant to determine risk management program maturity, MOST important element of RFP is:

A. Sample deliverable
B. Past experience of engagement team
C. Methodology used in assessment
D. References from other enterprises

Q8: Explanation

Correct Answer: C

Methodology illustrates the consultant's process and offers a basis to align expectations with execution of the assessment. Methodology establishes requirements of all parties involved.

Option Analysis

- **A - Incorrect:** Sample deliverable only shows presentation, not process
- **B - Incorrect:** Past experience is not as important as methodology
- **C - Correct:** Methodology shows how the assessment will be done
- **D - Incorrect:** References are important but not as important as methodology

Q9: New Law Impact

Question

Shortly after annual policy review, a new law may affect security requirements for HR system. Risk practitioner should:

- (A) Analyze what systems and technology-related processes may be impacted
- (B) Ensure adjustments are implemented during next review cycle
- (C) Initiate ad hoc revision of corporate policy
- (D) Notify system custodian to implement changes

Q9: Explanation

Correct Answer: A

Assessing what systems and technology-related processes may be impacted is the best course of action. The analysis must also determine whether existing controls already address the new requirements.

Option Analysis

- **A - Correct:** Assessment should precede any action
- **B - Incorrect:** Significant changes should trigger ad hoc reassessment
- **C - Incorrect:** Ad hoc amendment may be rash and unnecessary
- **D - Incorrect:** Changes need approval from process owner

Q10: Outsourced Data Processing Liability

Question

Enterprise outsourced personnel data processing and a regulatory violation occurs. Who will be held legally responsible?

A. Supplier, because it has operational responsibility
B. Enterprise, because it owns the data
C. Enterprise and supplier
D. Supplier, because it did not comply with contract

Q10: Explanation

Correct Answer: B

The enterprise retains responsibility for management of and adherence to policies, procedures and regulatory requirements. The regulatory authority will generally hold the enterprise responsible.

Option Analysis

- **A - Incorrect:** Regulatory authority will hold enterprise responsible
- **B - Correct:** Enterprise owns the data and remains responsible
- **C - Incorrect:** Regulatory authority holds enterprise responsible
- **D - Incorrect:** Supplier responsibilities are limited to contract terms

Q11: Evaluating Internal Controls

Question

Which role is responsible for evaluating effectiveness of existing internal information security controls?

A. Data owner
B. Senior management
C. End users
D. System auditor

Q11: Explanation

Correct Answer: D

The system auditor is responsible for providing continuous feedback to senior management about the effectiveness of internal controls within the enterprise.

Option Analysis

- **A - Incorrect:** Data owner defines business requirements
- **B - Incorrect:** Senior management ensures effectiveness but doesn't evaluate
- **C - Incorrect:** End users can identify flaws but are not responsible
- **D - Correct:** System auditor evaluates control effectiveness

Q12: Risk Management Program Effectiveness

Question

Which BEST ensures overall effectiveness of a risk management program?

- A Obtaining feedback from all end users
- B Assigning dedicated risk manager
- C Applying quantitative risk methodologies
- D Gaining participation of relevant stakeholders

Q12: Explanation

Correct Answer: D

Stakeholders directly or indirectly determine the risk response. Without having participation from enterprise stakeholders, the effectiveness of a risk management program cannot be guaranteed.

Option Analysis

- **A** - **Incorrect:** Feedback from all end users is generally not feasible
- **B** - **Incorrect:** Dedicated manager is less effective without stakeholder involvement
- **C** - **Incorrect:** Methodology selection depends on enterprise needs
- **D** - **Correct:** Stakeholder participation is essential

Q13: Risk-Based Objectives

Question

Which approach BEST helps an enterprise achieve risk-based organizational objectives?

- A Ensure asset owners perform annual risk assessments
- B Review and update risk register regularly
- C Assign steering committee to risk management
- D Embed risk management activities into business processes

Q13: Explanation

Correct Answer: D

The primary objective of embedding risk management activities into business processes is to achieve risk-based organizational objectives in the most effective manner possible.

Option Analysis

- **A - Incorrect:** Assessment alone does not achieve objectives
- **B - Incorrect:** Maintaining risk register tracks risk but doesn't achieve objectives
- **C - Incorrect:** Steering committee aids alignment but isn't as effective
- **D - Correct:** Embedding into processes achieves objectives effectively

Q14: Regulatory Body Reliance

Question

When assessing capability of risk management process, regulatory body would place GREATEST reliance on:

A. Peer review
B. Internal review
C. External review
D. Process capability review

Q14: Explanation

Correct Answer: C

Regulatory entities generally use assessments performed by an objective and independent third party. Of the choices presented, an external review is the most objective and independent.

Option Analysis

- **A - Incorrect:** Peer review has less independence
- **B - Incorrect:** Internal review may be subject to management influence
- **C - Correct:** External review is most objective and independent
- **D - Incorrect:** Doesn't indicate level of independence

Q15: Evaluating Current Risk Profile

Question

Company improving security program since last review one year ago. What should company do to evaluate current risk profile?

- A Review previous findings and ensure all issues resolved
- B Conduct follow-up audits in deficient areas
- C Monitor KRIs and use results for targeted assessments
- D Perform new enterprise risk assessment using independent expert

Q15: Explanation

Correct Answer: D

The best way to ensure that an enterprise's security posture is still within compliance is to conduct another risk assessment. Using an independent expert can provide more objective results.

Option Analysis

- **A - Incorrect:** New assessment indicates control effectiveness
- **B - Incorrect:** Changes may affect other areas; enterprise-wide assessment is better
- **C - Incorrect:** KRIs are one of many tools; not sufficient alone
- **D - Correct:** New risk assessment with independent expert is best

Q16: Greatest Risk of Inadequate Policy

Question

Which is GREATEST risk of a policy that defines data and system ownership inadequately?

A. Audit recommendations may not be implemented
B. Users may have unauthorized access to create, modify or delete data
C. User management coordination does not exist
D. Specific user accountability cannot be established

Q16: Explanation

Correct Answer: B

Without a policy defining who grants access to specific data or systems, the risk that employees receive system access without justified business purpose increases. Business objectives are best supported when authority to grant access is assigned to specific individuals.

Option Analysis

- **A - Incorrect:** Audit reports assign remediation owners
- **B - Correct:** Inappropriate access is the greatest risk
- **C - Incorrect:** This is a risk but not the greatest
- **D - Incorrect:** User accountability is established by unique IDs

Q17: Management Role in Risk Strategy

Question

Which BEST describes role of management in implementing a risk management strategy?

A. Ensure planning, budgeting and performance of IS components are appropriate

B. Assess and incorporate results of risk management into decision-making

C. Identify, evaluate and minimize risk to IT systems

D. Understand risk management process to develop training materials

Q17: Explanation

Correct Answer: B

Assessing and incorporating the results of risk management into the decision-making process best describes the role of senior management in establishing and implementing a risk management strategy.

Option Analysis

- **A - Incorrect:** This is CIO responsibility
- **B - Correct:** Management incorporates risk into decisions
- **C - Incorrect:** This is IT security manager responsibility
- **D - Incorrect:** This is corporate security trainer responsibility

Q18: Primary Focus of IT Risk Management

Question

The PRIMARY focus of managing IT-related business risk is to protect:

A. Information
B. Hardware
C. Applications
D. Databases

Q18: Explanation

Correct Answer: A

The primary objective for any enterprise is to protect mission-critical information based on a risk assessment.

Option Analysis

- **A - Correct:** Information is the primary focus
- **B - Incorrect:** Hardware is focus only if it stores/processes critical data
- **C - Incorrect:** Applications are focus only if they process critical data
- **D - Incorrect:** Databases are focus only if they store critical data

Q19: Best Risk Management Perspective

Question

Which can provide BEST perspective of risk management to employees and stockholders?

- A. An interdisciplinary team within the enterprise
- B. A third-party risk assessment service provider
- C. The enterprise's IT department
- D. The enterprise's internal compliance department

Q19: Explanation

Correct Answer: A

Assembling an interdisciplinary team to manage risk ensures that all areas are adequately considered in risk assessment and helps provide an enterprise-wide perspective on risk.

Option Analysis

- **A - Correct:** Interdisciplinary team provides enterprise-wide view
- **B - Incorrect:** Lacks internal knowledge and judgment
- **C - Incorrect:** IT department view is too narrow
- **D - Incorrect:** Compliance department focuses on regulatory compliance

Q20: Global Policy Approach

Question

Which approach to corporate policy BEST supports expansion to other regions with different local laws?

A. Global policy without provisions disputed at local levels
B. Global policy amended to comply with local laws
C. Global policy that complies with laws at headquarters
D. Local policies to accommodate laws within each region

Q20: Explanation

Correct Answer: B

A global policy including local amendments ensures alignment with local laws and regulations.

Option Analysis

- **A - Incorrect:** One policy for all locales is nearly impossible
- **B - Correct:** Global policy with local amendments ensures compliance
- **C - Incorrect:** Exposes enterprise to legal action and reputational loss
- **D - Incorrect:** Extremely expensive and may fail to leverage common practices

Q21: Data Classification Responsibility

Question

Who is MOST likely responsible for data classification?

- A Data user
- B Data owner
- C Data custodian
- D System administrator

Q21: Explanation

Correct Answer: B

The data owner is responsible for classifying data according to the enterprise's data classification scheme. The classification scheme then defines who is eligible to access the data and what controls are required.

Option Analysis

- **A - Incorrect:** Data user gains access based on business need
- **B - Correct:** Data owner classifies data
- **C - Incorrect:** Data custodian implements controls
- **D - Incorrect:** System administrator is a custodian

Q22: Security Governance Model Factor

Question

Which factor will have GREATEST impact on type of information security governance model adopted?

- A Number of employees
- B Enterprise's budget
- C Organizational structure
- D Type of technology used

Q22: Explanation

Correct Answer: C

Information security governance models depend significantly on the overall organizational structure.

Option Analysis

- **A - Incorrect:** Well-defined processes provide proper governance
- **B - Incorrect:** Budget does not dictate governance model
- **C - Correct:** Organizational structure is the primary factor
- **D - Incorrect:** Well-defined processes provide proper governance

Q23: Information Security Procedures

Question

Information security procedures should:

A. Be updated frequently as new software is released

B. Underline the importance of security governance

C. Define the allowable limits of behavior

D. Describe security baselines for each platform

Q23: Explanation

Correct Answer: A

Security procedures have to change frequently to keep up with changes in software. Because a procedure is a how-to document, it must be kept current with frequent changes in software.

Option Analysis

- **A - Correct:** Procedures must be updated with software changes
- **B - Incorrect:** High-level objectives are addressed in policy
- **C - Incorrect:** Security policies define behavioral limits
- **D - Incorrect:** Security standards define platform baselines

Q24: Greatest Benefit of Risk-Aware Culture

Question

Which is GREATEST benefit of a risk-aware culture?

- (A) Issues are escalated when suspicious activity is noticed
- (B) Controls are double-checked to anticipate issues
- (C) Individuals communicate with peers for knowledge sharing
- (D) Employees are self-motivated to learn about costs and benefits

Q24: Explanation

Correct Answer: A

Management benefits most from an escalation process because risk and incidents are reported in a timely manner. Escalation posture among employees is best developed through training and awareness programs.

Option Analysis

- **A - Correct:** Timely escalation benefits management most
- **B - Incorrect:** Double-checking is basic business practice
- **C - Incorrect:** Knowledge sharing is indirect benefit
- **D - Incorrect:** Cost-benefit learning is not primary expectation

Q25: Main Objective of IT Risk Management

Question

The MAIN objective of IT risk management is to:

A. Prevent loss of IT assets
B. Provide timely management reports
C. Ensure regulatory compliance
D. Enable risk-aware business decisions

Q25: Explanation

Correct Answer: D

IT risk management should be conducted as part of enterprise-wide risk management, whose ultimate objective is to support risk-aware business decisions.

Option Analysis

- **A - Incorrect:** Protecting assets is a subordinate goal
- **B - Incorrect:** Reporting is a subordinate goal
- **C - Incorrect:** Compliance is one objective, not the main
- **D - Correct:** Risk-aware business decisions is the ultimate objective

Q26: Global Compliance Approach

Question

Which is BEST approach for global enterprise subject to multiple governmental jurisdictions with differing requirements?

A. Bring all locations into conformity with aggregate requirements
B. Bring all locations into conformity with industry good practices
C. Establish baseline standard incorporating common requirements
D. Establish baseline standards and add supplemental standards as required

Q26: Explanation

Correct Answer: D

It is more efficient to establish a baseline standard and then develop additional standards for locations that must meet specific requirements.

Option Analysis

- **A - Incorrect:** Lowest common denominator may cause non-compliance
- **B - Incorrect:** Good practices may not meet all regulatory requirements
- **C - Incorrect:** Forcing all locations to comply places undue burden
- **D - Correct:** Baseline plus supplements is most efficient

Q27: Risk Management Plan Sign-off

Question

Who MUST give final sign-off on the IT risk management plan?

- A IT auditors performing risk assessment
- B Business process owners
- C Senior managers
- D IT security administrators

Q27: Explanation

Correct Answer: C

Senior managers understand performance metrics and indicators that measure the enterprise and its subsystems; they approved the policies and standards that govern the enterprise, and they have final responsibility for risk associated with audit findings and recommendations.

Option Analysis

- **A - Incorrect:** Auditors contribute but lack authority
- **B - Incorrect:** Process owners contribute but lack authority
- **C - Correct:** Senior managers have final responsibility
- **D - Incorrect:** Administrators contribute but lack authority

Q28: Security Boundary Purpose

Question

What is PRIMARY reason a risk practitioner determines the security boundary prior to conducting a risk assessment?

A. To decide which laws and regulations apply

B. To identify the scope of the risk assessment

C. To identify the business owners of the system

D. To decide whether quantitative or qualitative analysis is appropriate

Q28: Explanation

Correct Answer: B

Identifying the security boundary establishes the fundamental scope of inquiry, including the systems and components subject to assessment and those not subject to assessment.

Option Analysis

- **A - Incorrect:** Risk assessment itself considers laws/regulations
- **B - Correct:** Security boundary establishes scope
- **C - Incorrect:** Identifying business owners is secondary
- **D - Incorrect:** Security boundaries don't directly inform methodology choice

Q29: Most Effective Risk Program Management

Question

Which group would be MOST effective in managing and executing an enterprise's risk program?

- A Mid-level managers
- B Senior managers
- C Frontline employees
- D Incident response team

Q29: Explanation

Correct Answer: A

Mid-level managers are the best to manage and execute an enterprise's risk management program because they are the most centrally located within the organizational hierarchy, and they combine a sufficient breadth of influence with adequate proximity to day-to-day operations.

Option Analysis

- **A - Correct:** Mid-level managers combine influence with operational proximity
- **B - Incorrect:** Senior managers are too high organizationally
- **C - Incorrect:** Frontline employees lack power and influence
- **D - Incorrect:** Incident response team only manages a small portion

Q30: IT Steering Committee Composition

Question

IT steering committee will be BEST represented by:

A. Members of the executive board
B. High-level members of the IT department
C. IT experts from outside the enterprise
D. Key members from each department

Q30: Explanation

Correct Answer: D

The IT steering committee should be comprised of individuals from each department to ensure that the entire enterprise is represented and that all business objectives are more likely to be met.

Option Analysis

- **A - Incorrect:** Executive board only focuses on high-level goals
- **B - Incorrect:** IT only ignores business objectives
- **C - Incorrect:** External experts ignore business objectives
- **D - Correct:** Cross-departmental representation ensures business alignment

Q31: First Line of Defense Purpose

Question

Which is one of the MAIN purposes of the first line of defense in the three lines of defense model?

- A Ensure financial controls are in place
- B Ensure control deficiencies are addressed
- C Ensure risk management practices are effective
- D Ensure compliance with rules and regulations

Q31: Explanation

Correct Answer: B

In the first line, operational managers own the risk and address it by mitigating control deficiencies.

Option Analysis

- **A - Incorrect:** Financial risk is only one category
- **B - Correct:** First line addresses control deficiencies
- **C - Incorrect:** Risk management is second line
- **D - Incorrect:** Ensuring compliance is second line

Q32: Risk Response Selection

Question

The PRIMARY consideration when selecting a risk response technique is:

A. Coverage of all identified risk
B. Availability of resources
C. Enterprise goals and objectives
D. Standards and industry good practices

Q32: Explanation

Correct Answer: C

The risk response will be based primarily on goals and objectives of the enterprise. Risk can harm these goals and must be mitigated according to priority.

Option Analysis

- **A - Incorrect:** Address mission-critical risk, not all risk
- **B - Incorrect:** Resources are secondary to goals
- **C - Correct:** Enterprise goals drive risk response
- **D - Incorrect:** Standards are followed after mitigation technique is selected

Q33: First Policy to Create

Question

CIO asked to create all IT policies and procedures. Which should the CIO create FIRST?

- A Strategic IT plan
- B Data classification scheme
- C Information architecture document
- D Technology infrastructure plan

Q33: Explanation

Correct Answer: A

The strategic IT plan is the first policy to create when developing an enterprise's governance model.

Option Analysis

- **A - Correct:** Strategic plan comes first
- **B - Incorrect:** Strategic plan comes before data classification
- **C - Incorrect:** Strategic plan comes before information architecture
- **D - Incorrect:** Strategic plan comes before technology infrastructure plan

Q34: Greatest Concern for Risk Practitioner

Question

Which should be of MOST concern to a risk practitioner?

- A Failure to notify public of intrusion
- B Failure to notify police of attempted intrusion
- C Failure to internally report a successful attack
- D Failure to examine access rights periodically

Q34: Explanation

Correct Answer: C

Failure to report a successful intrusion is a serious concern to the risk practitioner and could—in some instances—be interpreted as abetting.

Option Analysis

- **A - Incorrect:** Reporting to public is not a requirement
- **B - Incorrect:** Attempted intrusion rarely requires police notification
- **C - Correct:** Failure to report successful attack is serious
- **D - Incorrect:** Lack of periodic review is a concern but not as serious

Q35: Risk Management Capabilities Insight

Question

Which review will provide MOST insight into enterprise's risk management capabilities?

A. Capability maturity model review
B. Capability comparison with industry standards
C. Self-assessment of capabilities
D. Internal audit review of capabilities

Q35: Explanation

Correct Answer: A

Capability maturity modeling allows an enterprise to understand its level of maturity in its risk capabilities, which is an indicator of operational readiness and effectiveness.

Option Analysis

- **A - Correct:** Maturity model shows readiness and effectiveness
- **B - Incorrect:** Only shows existence/non-existence of capabilities
- **C - Incorrect:** Only shows existence/non-existence
- **D - Incorrect:** Only shows existence/non-existence

Q36: Leveraging Internal Audit

Question

Risk practitioner BEST leverages work performed by internal audit by having it:

A. Design, implement and maintain ERM process
B. Manage and assess overall risk awareness
C. Evaluate ongoing changes to enterprise risk factors
D. Assist in monitoring, evaluating, examining and reporting on controls

Q36: Explanation

Correct Answer: D

The internal audit function is responsible for assisting management and the board of directors in monitoring, evaluating, examining and reporting on internal controls, regardless of whether an ERM function has been implemented.

Option Analysis

- **A - Incorrect:** Design/implementation is management responsibility
- **B - Incorrect:** Risk awareness is risk governance responsibility
- **C - Incorrect:** Evaluating changes is not internal audit responsibility
- **D - Correct:** Internal audit assists in monitoring and reporting on controls

Q37: Biggest Concern for CISO

Question

Which is BIGGEST concern for CISO regarding interconnections with systems outside the enterprise?

- A. Requirements to comply with each other's contractual security obligations
- B. Uncertainty that the other system will be available as needed
- C. The ability to perform risk assessments on the other system
- D. Ensuring communications are encrypted through VPN tunnel

Q37: Explanation

Correct Answer: A

Ensuring that both systems comply with mutual contractual security obligations should be the primary concern of the risk practitioner. If one system fails to comply, both will likely miss their respective security obligations.

Option Analysis

- **A - Correct:** Contractual compliance is primary concern
- **B - Incorrect:** Availability is business owner's concern
- **C - Incorrect:** May or may not be a concern based on agreement
- **D - Incorrect:** Encryption depends on type of data transmitted

Q38: IT Organizational Structure Type

Question

CIO creates all IT policies managed by IT steering committee making all IT decisions. Which type of IT organizational structure?

- A Project-based
- B Centralized
- C Decentralized
- D Divisional

Q38: Explanation

Correct Answer: B

Within a centralized IT organizational structure, one group makes all decisions for the entire enterprise.

Option Analysis

- **A - Incorrect:** Project-based groups are temporary
- **B - Correct:** Centralized has one decision-making group
- **C - Incorrect:** Decentralized decisions made by each division
- **D - Incorrect:** Divisional has groups by geography/product

Q39: Aggregated Monitoring Results

Question

Aggregated results of continuous monitoring activities are BEST communicated to:

A. Risk owner
B. Technical staff
C. Audit department
D. Information security manager

Q39: Explanation

Correct Answer: A

The risk owner is the most suitable target audience for aggregated results of continuous monitoring; the risk owner is accountable for the fact that appropriate risk responses are executed in alignment with the enterprise's risk appetite.

Option Analysis

- **A - Correct:** Risk owner is accountable
- **B - Incorrect:** Technical staff need granular information
- **C - Incorrect:** Audit may review but is not primary recipient
- **D - Incorrect:** Security manager is secondary audience

Q40: Risk Awareness Program

Question

Which is PRIMARY consideration when developing an IT risk awareness program?

A. Why technology risk is owned by IT
B. How technology risk can affect each attendee's area of business
C. How business process owners can transfer technology risk
D. Why technology risk is more difficult to manage than other risk

Q40: Explanation

Correct Answer: B

Stakeholders must understand how IT-related risk affects the overall business and how potential threats and vulnerabilities can jeopardize the enterprise's people, processes and technology.

Option Analysis

- **A - Incorrect:** IT does not own technology risk
- **B - Correct:** Business impact is primary
- **C - Incorrect:** Transferring risk is part of risk response
- **D - Incorrect:** This may or may not be true

Q41: IT Success Against Business Requirements

Question

Management wants to ensure IT is successful in delivering against business requirements. Which BEST supports that effort?

A. An internal control system or framework
B. A cost-benefit analysis
C. A return on investment analysis
D. A benchmark process

Q41: Explanation

Correct Answer: A

For IT to be successful in delivering against business requirements, management should develop an internal control system that supports its business requirements.

Option Analysis

- **A - Correct:** Internal control system supports business alignment
- **B - Incorrect:** Cost-benefit is useful but not most important
- **C - Incorrect:** ROI is just one metric
- **D - Incorrect:** Benchmarking comes after sound internal control framework

Q42: Risk Appetite Alignment

Question

It is MOST important that risk appetite be aligned with business objectives to ensure that:

A. Resources are directed toward areas of low risk tolerance
B. Major risk is identified and eliminated
C. IT and business goals are aligned
D. The risk strategy is adequately communicated

Q42: Explanation

Correct Answer: A

Risk appetite refers to the amount of risk that an enterprise is willing to take on in pursuit of value. Aligning it with business objectives allows an enterprise to evaluate and deploy valuable resources toward those objectives with low risk tolerance for loss.

Option Analysis

- **A - Correct:** Resources directed to low tolerance areas
- **B - Incorrect:** Risk cannot be eliminated
- **C - Incorrect:** Alignment affects more than IT and business
- **D - Incorrect:** Communication does not depend on alignment

Q43: Outdated Security Policy

Question

Which causes GREATEST concern reviewing a corporate information security policy that is out of date?

A. Was not reviewed within the last three years
B. Is missing newer technologies/platforms
C. Was not updated for new locations
D. Does not enforce control monitoring

Q43: Explanation

Correct Answer: A

Not reviewing the policy for three years and updating it as necessary does not follow good practices and is the greatest concern.

Option Analysis

- **A - Correct:** Not reviewing for three years is greatest concern
- **B - Incorrect:** Corporate policies generally don't require modification for specific technologies
- **C - Incorrect:** Well-written policy accommodates multiple locations
- **D - Incorrect:** Lack of control monitoring is a concern but not as great as policy review

Q44: Accountability for Business Risk

Question

Who is accountable for business risk related to IT?

- A Chief information officer
- B Chief financial officer
- C Users of IT services
- D Chief architect

Q44: Explanation

Correct Answer: C

Ultimately, the enterprise (i.e., the users of IT services) owns business-related risk, including the risk related to the use of IT. The business should set the mandate for risk management, provide the resources and funding to support a risk management plan.

Option Analysis

- **A - Incorrect:** CIO supports business but doesn't own risk
- **B - Incorrect:** CFO tracks costs but doesn't own risk
- **C - Correct:** Enterprise users own business risk
- **D - Incorrect:** Chief architect mitigates risk but doesn't own it

Q45: Expansion Risk Reporting

Question

Enterprise expanding into new nearby domestic locations. Which is MOST important to report?

- A Competitor analysis
- B Legal and regulatory requirements
- C Political issues
- D Potential of natural disasters

Q45: Explanation

Correct Answer: B

Legal and regulatory requirements are most likely to change when moving to a nearby location because each municipality may enforce significantly different regulations, including environmental requirements, taxation and others.

Option Analysis

- **A - Incorrect:** Competitors likely won't change
- **B - Correct:** Legal requirements vary by municipality
- **C - Incorrect:** Political issues unlikely to change
- **D - Incorrect:** Natural disasters unlikely to change

Q46: True Statement about IT Risk

Question

Which is true about IT risk?

- A IT risk cannot be assessed and measured quantitatively
- B IT risk should be calculated separately from business risk
- C IT risk management is the responsibility of the IT department
- D IT risk exists regardless of whether it is detected or recognized

Q46: Explanation

Correct Answer: D

The enterprise must identify, acknowledge and respond to risk; ignorance of risk is not acceptable.

Option Analysis

- **A - Incorrect:** IT risk can be assessed both quantitatively and qualitatively
- **B - Incorrect:** IT risk is one type of business risk
- **C - Incorrect:** IT risk is responsibility of senior management
- **D - Correct:** Risk exists regardless of detection

Q47: Selecting Risk Management Methodology

Question

Which is MOST important when selecting an appropriate risk management methodology?

A. Risk culture
B. Countermeasure analysis
C. Cost-benefit analysis
D. Risk transfer strategy

Q47: Explanation

Correct Answer: A

Without understanding risk culture—how and why an enterprise makes decisions regarding risk—one cannot select a risk management methodology.

Option Analysis

- **A - Correct:** Risk culture informs methodology selection
- **B - Incorrect:** Countermeasure analysis targets specific attacks
- **C - Incorrect:** Cost-benefit does not inform methodology selection
- **D - Incorrect:** Risk transfer is not the basis for methodology selection

Q48: Determining Risk Appetite Compliance

Question

Which BEST determines compliance with the risk appetite of an enterprise?

A. Balance between preventive and detective controls
B. Inherent risk and acceptable risk level
C. Residual risk and acceptable risk level
D. Balance between countermeasures and preventive controls

Q48: Explanation

Correct Answer: C

Considering residual risk in terms of acceptable risk yields risk that is appropriately balanced after the application of controls. In this context, management can decide to accept risk or apply additional controls based on current standards of acceptable risk.

Option Analysis

- **A - Incorrect:** Controls may have been from earlier risk analysis
- **B - Incorrect:** Inherent risk alone is insufficient
- **C - Correct:** Residual risk vs acceptable risk determines compliance
- **D - Incorrect:** Countermeasures don't help evaluate risk appetite

Q49: Monitoring External Requirements

Question

A key objective when monitoring IS control effectiveness against external requirements is to:

A. Design applicable security controls for external audits
B. Create IS policy provisions for third parties
C. Ensure legal obligations have been satisfied
D. Identify legal obligations that apply

Q49: Explanation

Correct Answer: C

Legal obligations are one of the principal external requirements that necessitate compliance monitoring.

Option Analysis

- **A - Incorrect:** Control design occurs in risk treatment phase
- **B - Incorrect:** Policy creation occurs before monitoring
- **C - Correct:** Legal obligations must be monitored for compliance
- **D - Incorrect:** Identification occurs before risk treatment

Q50: Overall Risk Status

Question

Which provides an overall risk status of the enterprise?

A. Risk management
B. Risk analysis
C. Risk appetite
D. Risk profile

Q50: Explanation

Correct Answer: D

The risk profile provides the current overall portfolio of the identified risk to which the enterprise is exposed. Because the profile is updated with evolving and new risk, it provides the enterprise's current risk status.

Option Analysis

- **A - Incorrect:** Risk management encompasses coordinated activities
- **B - Incorrect:** Risk analysis is point-in-time
- **C - Incorrect:** Risk appetite is broad acceptance level
- **D - Correct:** Risk profile provides current status

Q51: Firewall Deviation Detection

Question

Which activity should a risk professional perform to determine whether firewall deployments are deviating from security policy?

- A Review firewall parameter settings
- B Review firewall intrusion prevention system logs
- C Review firewall hardening procedures
- D Analyze firewall log file for recent attacks

Q51: Explanation

Correct Answer: A

Firewall parameter settings will tie in with the configurations linked to the governing security policy. If the parameter settings differ from what policy states or requires, then there is a deviation.

Option Analysis

- **A - Correct:** Parameters show compliance with policy
- **B - Incorrect:** IPS logs show blocked packets, not configuration
- **C - Incorrect:** Hardening procedures show what was expected, not actual
- **D - Incorrect:** Attacks may not be covered in security policy

Q52: Continuous Risk Management Benefit

Question

Which is MOST significant benefit of implementing continuous risk management process?

- A Complies with external regulators' requirements
- B Captures changes to the enterprise's risk profile
- C Ensures stakeholders are linked to identified risk
- D Ensures timely action is taken to mitigate risk

Q52: Explanation

Correct Answer: B

A continuous risk management process ensures changes to the enterprise's risk profile are captured.

Option Analysis

- **A - Incorrect:** Compliance is not the aim of continuous process
- **B - Correct:** Captures changes to risk profile
- **C - Incorrect:** Linking stakeholders is not the aim
- **D - Incorrect:** Timely mitigation is not the aim

Q53: Risk Response When Risk Exceeds Appetite

Question

Senior management defined risk appetite as moderate. Business-critical application poses high risk. What is NEXT action?

- (A) Remove high-risk application and replace with another system
- (B) Recommend management increase acceptable risk level
- (C) Assess impact of planned controls to the application
- (D) Restrict access to application only to trusted users

Q53: Explanation

Correct Answer: C

The risk practitioner should determine whether the planned implementation of new controls on the system may lower the risk from high to moderate or low before taking any further action.

Option Analysis

- **A - Incorrect:** Removal may cause unacceptable downtime
- **B - Incorrect:** This is task for business owners, not risk practitioner
- **C - Correct:** Assess whether controls can reduce risk
- **D - Incorrect:** Restricting access may not mitigate high risk

Q54: Risk Profile Development

Question

Which BEST assists in development of the risk profile?

A. Presence of preventive and detective controls

B. Inherent risk and detection risk

C. Cost-benefit analysis of controls

D. Likelihood and impact of risk

Q54: Explanation

Correct Answer: D

Likelihood and impact of risk help in the development of the risk profile.

Option Analysis

- **A - Incorrect:** Controls alone don't help
- **B - Incorrect:** Inherent and detection risk alone don't help
- **C - Incorrect:** Cost-benefit helps select controls, not develop profile
- **D - Correct:** Likelihood and impact are fundamental to risk profile

Q55: Multi-Location Handbook Concern

Question

Enterprise expanded into Europe, Asia and Latin America. Single-version, multi-language employee handbook last updated three years ago. Which is of MOST concern?

- A Handbook may not have been correctly translated
- B Newer policies may not be included
- C Expired policies may be included
- D Handbook may violate local laws and regulations

Q55: Explanation

Correct Answer: D

Because customs and laws affect an enterprise's ability to operate in a given location, and because both customs and laws vary by state and by country, it is critical for the employee handbook to acknowledge and account for regional domestic and national differences.

Option Analysis

- **A - Incorrect:** Translation errors are less damaging than law violations
- **B - Incorrect:** Law compliance is more important
- **C - Incorrect:** Law compliance is more important
- **D - Correct:** Local law compliance is most critical

Q56: Annual Loss Expectancy Formula

Question

An asset's annual loss expectancy is calculated as the:

A. EF multiplied by ARO
B. SLE multiplied by EF
C. SLE multiplied by ARO
D. Asset value multiplied by SLE

Q56: Explanation

Correct Answer: C

ALE is calculated by multiplying the SLE by the ARO (the number of times the enterprise expects the loss to occur).

Option Analysis

- **A - Incorrect:** Wrong formula
- **B - Incorrect:** Wrong formula
- **C - Correct:** ALE = SLE × ARO
- **D - Incorrect:** Wrong formula

Q57: Effective Information Risk Management

Question

Which is BEST indicator of an effective information risk management program?

A. Security policy is made widely available
B. Risk is considered before all decisions
C. Security procedures are updated annually
D. Risk assessments occur on an annual basis

Q57: Explanation

Correct Answer: B

Defining information risk in advance of business decisions best ensures that risk tolerance remains at approved levels.

Option Analysis

- **A - Incorrect:** Making policy available facilitates success but isn't critical
- **B - Correct:** Risk-based decisions are key
- **C - Incorrect:** Procedures only need updating if policy changes
- **D - Incorrect:** Annual assessments facilitate but aren't as critical

Q58: Risk Management Strategic Plans

Question

Risk management strategic plans are MOST effective when developed for:

A. The enterprise as a whole
B. Each individual system based on technology
C. Every location based on geographic threats
D. End-to-end business processes

Q58: Explanation

Correct Answer: A

Risk management strategic plans are most effective when they are created and followed by the entire enterprise.

Option Analysis

- **A - Correct:** Enterprise-wide plans are most effective
- **B - Incorrect:** Creating per technology creates complexity
- **C - Incorrect:** Geographic plans don't account for other threats
- **D - Incorrect:** Per-process plans may overlap and conflict

Q59: Risk Appetite Consideration

Question

Which is MOST important when considering the risk appetite of an enterprise?

- A Capacity of enterprise to absorb loss
- B Definition of responsibilities for risk management
- C Line of business and typical risk of industry
- D Culture and predisposition toward risk taking

Q59: Explanation

Correct Answer: D

When considering risk appetite, two major factors are relevant: the management culture and the predisposition toward risk taking.

Option Analysis

- **A - Incorrect:** Capacity is a mitigation factor, not appetite
- **B - Incorrect:** Responsibilities say nothing about appetite
- **C - Incorrect:** Industry risk doesn't determine single enterprise appetite
- **D - Correct:** Culture and predisposition are primary

Q60: Enterprise-Wide Risk Framework Purpose

Question

PRIMARY purpose of adopting an enterprise-wide risk management framework is to:

- A Allow flexibility to adjust risk response strategy
- B Centralize responsibility for maintenance
- C Enable a consistent approach to risk response
- D Avoid higher costs for risk reduction

Q60: Explanation

Correct Answer: C

Enabling consistent risk response is a key objective of the risk management framework.

Option Analysis

- **A - Incorrect:** Framework enables consistency while allowing flexibility
- **B - Incorrect:** Risk management is everyone's responsibility
- **C - Correct:** Consistent approach is key
- **D - Incorrect:** Cost avoidance is good practice but not primary purpose

Q61: Risk Tolerance Example

Question

Review finds projects exceed timelines/budget by nearly 10

A. Risk avoidance
B. Risk tolerance
C. Risk acceptance
D. Risk mitigation

Q61: Explanation

Correct Answer: B

Risk tolerance is the permissible deviation from declared risk appetite levels.

Option Analysis

- **A - Incorrect:** Avoidance terminates activity
- **B - Correct:** Tolerance is acceptable deviation
- **C - Incorrect:** Acceptance means no action taken
- **D - Incorrect:** Mitigation uses countermeasures

Q62: Computing Annual Loss Exposure

Question

Which is MOST useful when computing annual loss exposure?

A. Cost of existing controls
B. Number of vulnerabilities
C. Net present value of asset
D. Business value of asset

Q62: Explanation

Correct Answer: D

Annual loss exposure is a function of the value of the information asset and the impact if a given potential risk should materialize.

Option Analysis

- **A - Incorrect:** Cost of controls not used in calculation
- **B - Incorrect:** Number of vulnerabilities doesn't determine exposure
- **C - Incorrect:** NPV may not reflect true risk
- **D - Correct:** Business value is fundamental

Q63: GRC Tool Major Risk

Question

Which is MAJOR risk associated with use of governance, risk and compliance tools?

A. Misinterpretation of dashboard's output
B. Incomplete or inaccurate coverage
C. Obsolescence of content
D. Complex integration of diverse requirements

Q63: Explanation

Correct Answer: C

A GRC application has to be updated regularly with current regulations, policies, etc. Obsolete content renders a GRC outdated.

Option Analysis

- **A - Incorrect:** Misinterpretation is easily corrected by training
- **B - Incorrect:** Incomplete coverage can be addressed
- **C - Correct:** Obsolescence is the greatest risk
- **D - Incorrect:** Tools are designed to integrate requirements

Q64: Need to Review Risk Practices

Question

Which signifies the need to review an enterprise's risk practices?

- A Business owners regularly challenge risk assessment findings
- B Manufacturing assigns its own internal risk management roles
- C Finance department finds exceptions during yearly risk review
- D Sales department procedures last reviewed 11 months ago

Q64: Explanation

Correct Answer: A

An enterprise's risk management practices must be clearly understood and supported by business stakeholders. Business owners who challenge the risk assessment findings either do not support the findings or do not understand them clearly.

Option Analysis

- **A - Correct:** Challenge indicates need for review
- **B - Incorrect:** Assigning roles is what departments should do
- **C - Incorrect:** Finding exceptions is normal
- **D - Incorrect:** Annual review is sufficient

Q65: Relevance Risk

Question

Correct information was not received by necessary recipients in suitable time. This is:

A. Integrity risk
B. Availability risk
C. Access risk
D. Relevance risk

Q65: Explanation

Correct Answer: D

Relevance risk is a composite form of business risk, requiring both integrity and availability to be addressed for it to be reasonably controlled. Transmitting information to the necessary recipients in a timely manner also creates tension with access (security) risk.

Option Analysis

- **A - Incorrect:** Integrity is incomplete/inaccurate data
- **B - Incorrect:** Availability is only one possible reason
- **C - Incorrect:** Access risk is unauthorized disclosure
- **D - Correct:** Relevance risk covers timeliness and correctness

Q66: Best Risk Assessment Output

Question

Which risk assessment output is MOST suitable to help justify an information security program?

A. Inventory of risk
B. Documented threats
C. Evaluation of consequences
D. List of appropriate controls

Q66: Explanation

Correct Answer: D

A list of information security controls corresponding to risk scenarios identified during risk assessment is one of the primary deliverables of the risk assessment exercise. The list demonstrates due consideration of risk and applicable controls to address the risk.

Option Analysis

- **A - Incorrect:** Doesn't cover how risk will be addressed
- **B - Incorrect:** Doesn't explain how risk will be reduced
- **C - Incorrect:** Doesn't represent controls
- **D - Correct:** List of controls demonstrates risk mitigation

Q67: Ultimate Accountability for Risk

Question

Accountability for risk ultimately belongs to the:

A. Chief risk officer
B. Compliance officer
C. Chief financial officer
D. Board of directors

Q67: Explanation

Correct Answer: D

The board of directors of an enterprise has ultimate accountability to shareholders, customers, employees and the general public.

Option Analysis

- **A - Incorrect:** CRO has responsibilities but not ultimate accountability
- **B - Incorrect:** Compliance officer has responsibility but not ultimate
- **C - Incorrect:** CFO has major responsibilities but not ultimate
- **D - Correct:** Board has ultimate accountability

Q68: Outdated IT Standards

Question

Risk assessment reveals many corporate IT standards have not been updated. BEST course of action is:

A. Review standards against current requirements and determine adequacy

B. Determine standards should be updated annually

C. Report that IT standards are adequate

D. Review IT policy to see how frequently standards should be updated

Q68: Explanation

Correct Answer: A

The risk practitioner should verify that the standards are still adequate. Standards that are lacking should be updated.

Option Analysis

- **A - Correct:** Review and determine adequacy
- **B - Incorrect:** Standards may or may not need annual updates
- **C - Incorrect:** Cannot report adequacy without review
- **D - Incorrect:** Policy review won't determine adequacy

Q69: Accountability for Third-Party App Risk

Question

Marketing procures third-party application. Application poses risk to data privacy regulations in certain regions. Who is accountable if implemented globally?

- A IT department
- B Data privacy officer
- C Chief risk officer
- D Marketing department

Q69: Explanation

Correct Answer: D

The marketing department is the business owner of the application and, therefore, must be accountable. According to ISACA's COBIT framework, accountability rests with those who own the required resources and have the authority to approve the execution and accept the outcome.

Option Analysis

- **A - Incorrect:** IT is responsible, not accountable
- **B - Incorrect:** Privacy officer is advisory
- **C - Incorrect:** CRO is advisory
- **D - Correct:** Marketing owns the application

Q70: Risk Treatment Decisions Ownership

Question

Who owns the risk treatment decisions?

- A Control owner
- B Chief information officer
- C IT security manager
- D Senior management

Q70: Explanation

Correct Answer: D

Senior management ultimately owns the risk and would make risk treatment decisions.

Option Analysis

- **A - Incorrect:** Control owner would not make risk treatment decisions
- **B - Incorrect:** CIO is part of senior management but not sole decision-maker
- **C - Incorrect:** IT security manager implements, doesn't decide
- **D - Correct:** Senior management owns risk

Q71: Responsibility for Third-Party App Risk

Question

Marketing procures third-party application with data privacy risk. Which role will be responsible for the risk?

- A Marketing department
- B IT department
- C Data privacy officer
- D Chief risk officer

Q71: Explanation

Correct Answer: B

The IT department is responsible for the risk posed by this application. The IT department has a policy in place that states that no tool or application can be implemented without a risk assessment and mitigation of all risk to an acceptable level.

Option Analysis

- **A - Incorrect:** Marketing is accountable, not responsible
- **B - Correct:** IT is responsible for risk assessment
- **C - Incorrect:** Privacy officer is advisory
- **D - Incorrect:** CRO is advisory

Q72: Justifying Encryption

Question

Which provides GREATEST support to risk practitioner recommending encryption as risk mitigation?

A. Benchmarking with peers
B. Evaluating public reports on encryption
C. Developing a business case
D. Scanning unencrypted systems for vulnerabilities

Q72: Explanation

Correct Answer: C

A business case documents how encryption addresses risk and illustrates that risk losses can be reduced by recommended controls.

Option Analysis

- **A - Incorrect:** Peers have different risk environments
- **B - Incorrect:** Need to analyze in enterprise context
- **C - Correct:** Business case justifies the control
- **D - Incorrect:** Vulnerability assessment without business justification doesn't help

Q73: Additional Stakeholder for Risk Reporting

Question

Marketing procures third-party application with data privacy risk. Which additional stakeholder should be included in reporting?

A. Chief privacy officer
B. Third-party vendor
C. Business continuity manager
D. Audit manager

Q73: Explanation

Correct Answer: A

The chief privacy officer will offer support in defining controls that will be implemented to address and mitigate the data transfer and data privacy requirements. If the application must be used by the business, the chief privacy officer ultimately becomes a critical stakeholder.

Option Analysis

- **A - Correct:** Privacy officer is critical stakeholder
- **B - Incorrect:** No need to inform vendor
- **C - Incorrect:** No need to inform BC manager
- **D - Incorrect:** No need to inform audit manager

Q74: Cloud Email Retention

Question

Enterprise learned cloud email provider was never contracted to back up messages despite retention policy requiring three-year saving. Which would have BEST safeguarded?

- A Providing contractor with retention policy upfront
- B Validating company policies to provider's contract
- C Providing contractor with email retention policy upfront
- D Backing up data on internal network nightly

Q74: Explanation

Correct Answer: B

The initial review of third-party services should confirm that vendors are contractually required to enforce all internal policies—including the policy on record retention if the enterprise's record retention policy specifically covers data that will be managed by a third party.

Option Analysis

- **A - Incorrect:** Providing policy doesn't legally obligate
- **B - Correct:** Contractual validation is essential
- **C - Incorrect:** Providing policy doesn't legally obligate
- **D - Incorrect:** Internal backup doesn't solve policy variance issue

Q75: Personal Device Policy

Question

If enterprise does not have formal policy regarding personal devices in workplace, what should risk practitioner recommend?

A. Introduce remote wipe functionality

B. Implement exception process based on approvals

C. Update incident response procedures

D. Create and maintain inventory of personal devices

Q75: Explanation

Correct Answer: B

If employees are allowed to attach personal devices to a company network but there is no formal policy in place, employees should be required to gain approval from management, and this approval should be documented and reviewed in a security exception form based on the exception process.

Option Analysis

- **A - Incorrect:** Implementation would be part of formal policy
- **B - Correct:** Exception process is needed without formal policy
- **C - Incorrect:** Procedures can't be updated without policy
- **D - Incorrect:** Inventorying doesn't reduce risk

Q76: Risk Management Application

Question

To be effective, risk management should be applied to:

A. Elements identified by risk assessment

B. Any area that exceeds acceptable risk levels

C. All enterprise activities

D. Only areas that have potential impact

Q76: Explanation

Correct Answer: C

Although not all enterprise activities entail unacceptable risk, the practice of risk management is ideally applied to all enterprise activities.

Option Analysis

- **A - Incorrect:** All activities subject to risk management oversight
- **B - Incorrect:** Must be holistic, not limited to unacceptable risk
- **C - Correct:** Applied to all enterprise activities
- **D - Incorrect:** Determining impact is part of risk management

Q77: Corporate Security Policy Basis

Question

Development of corporate information security policy should PRIMARILY be based on:

A. Vulnerabilities
B. Threats
C. Assets
D. Impacts

Q77: Explanation

Correct Answer: C

The corporate information security policy is based on management's commitment to protect the assets of the enterprise (and relevant information of its business partners) from threats, risk and exposures that could occur.

Option Analysis

- **A - Incorrect:** Vulnerabilities don't pose risk without threats
- **B - Incorrect:** Policy addresses protection of assets from threats
- **C - Correct:** Assets are the basis for protection
- **D - Incorrect:** Impact doesn't drive policy development

Q78: Enabling Risk-Aware Decisions

Question

Which MOST enables risk-aware business decisions?

- A Robust information security policies
- B Exchange of accurate and timely information
- C Skilled risk management personnel
- D Robust process controls

Q78: Explanation

Correct Answer: B

Robust exchange of information enables management to optimize risk-related decisions. Accuracy and timeliness of information are critical success factors.

Option Analysis

- **A - Incorrect:** Policies focus on protecting business
- **B - Correct:** Accurate/timely information enables decisions
- **C - Incorrect:** Personnel enable decisions but bidirectional flow is needed
- **D - Incorrect:** Process controls exist for known threats

Q79: Initial Risk Management Program Requirements

Question

Which MUST be met during initial stages of developing a risk management program?

A. Management establishes ownership of identified risk
B. Information security policies and standards are established
C. Management committee exists to provide program oversight
D. Context and purpose of program are defined

Q79: Explanation

Correct Answer: D

Initial requirements to determine the enterprise's purpose for creating an information security risk management program include determining the desired outcomes and defining objectives.

Option Analysis

- **A - Incorrect:** Ownership occurs later
- **B - Incorrect:** Policies are based on decisions in planning phase
- **C - Incorrect:** Oversight is established later
- **D - Correct:** Context and purpose come first

Q80: BYOD Policy Effectiveness

Question

Which approach MOST enables BYOD policy to be effective?

- A Obtaining signed acceptance from users
- B Educating users on acceptable and unacceptable practices
- C Requiring users to read policy and updates
- D Clearly stating disciplinary action for noncompliance

Q80: Explanation

Correct Answer: B

A BYOD policy that is approved and communicated will not be effective without proper training of all users.

Option Analysis

- **A - Incorrect:** Sign-off doesn't imply understanding
- **B - Correct:** Training is essential for effectiveness
- **C - Incorrect:** Reading alone won't ensure understanding
- **D - Incorrect:** Disciplinary action is important but not best option

Q81: New Regulation First Step

Question

New regulation for safeguarding information comes to IT manager's attention. Manager should FIRST:

A. Meet with stakeholders to decide how to comply
B. Analyze key risk in compliance process
C. Update existing security/privacy policy
D. Assess whether existing controls meet the regulation

Q81: Explanation

Correct Answer: D

The first step is to understand the impact and requirements of the new regulation, which includes assessing how the enterprise will comply with the regulation and to what extent existing controls support compliance. The risk practitioner should then assess any existing gaps.

Option Analysis

- **A - Incorrect:** Meeting is subsequent
- **B - Incorrect:** Analysis is subsequent
- **C - Incorrect:** Updating policy is subsequent
- **D - Correct:** Assessment comes first

Q82: Compliance Risk and Corrective Actions

Question

Which document BEST identifies compliance risk and corrective actions in progress?

A. Internal audit report
B. Risk register
C. External audit report
D. Risk assessment report

Q82: Explanation

Correct Answer: B

A risk register provides a report of all current identified risk within an enterprise (including compliance risk) and tracks the status of corrective actions or exceptions.

Option Analysis

- **A - Incorrect:** Audit reports track findings but not necessarily compliance risk
- **B - Correct:** Risk register tracks all risk and corrective actions
- **C - Incorrect:** External audits focus on one requirement at a time
- **D - Incorrect:** Risk assessment may include compliance risk but doesn't track corrective actions

Q83: Impact on Security Governance Models

Question

Which will have MOST significant impact on standard information security governance models?

A. Number of employees and consulting staff
B. Cultural differences between physical locations
C. Complexity of organizational structure
D. Uncertainty in legislative requirements

Q83: Explanation

Correct Answer: C

Information security governance models are highly dependent on the complexity of the organizational structure. Elements that affect organizational structure include multiple business units, dispersion of multiple functions, multiple leadership hierarchies and multiple lines of communication.

Option Analysis

- **A - Incorrect:** Well-defined processes provide governance
- **B - Incorrect:** Well-defined processes provide governance
- **C - Correct:** Organizational structure is primary
- **D - Incorrect:** Good governance models handle legislative requirements

Q84: Highest Tolerance for Public Cloud

Question

Senior management will MOST likely have highest tolerance for moving which to public cloud?

A. Credit-card processing
B. Research and development
C. Legacy financial system
D. Corporate email system

Q84: Explanation

Correct Answer: D

Consideration for moving processes and information to the cloud should include the criticality, complexity and classification of the data. Of the options offered, the corporate email system has the least competitive distinction, complexity, and sensitive/highly classified information.

Option Analysis

- **A - Incorrect:** Credit-card processing is high security
- **B - Incorrect:** R&D contains confidential proprietary information
- **C - Incorrect:** Legacy financial system is sensitive and complex
- **D - Correct:** Email has least competitive distinction

Q85: Risk Profile Consideration

Question

Which is MOST important to consider in relation to a risk profile?

- A Summary of regional loss events
- B Aggregated risk to the enterprise
- C Description of critical risk
- D Analysis of historical loss events

Q85: Explanation

Correct Answer: B

The risk profile is based on the aggregated risk to the enterprise, including historical risk, critical risk and emerging risk.

Option Analysis

- **A - Incorrect:** Regional events are one component
- **B - Correct:** Aggregated risk is the basis
- **C - Incorrect:** All risk is considered, not just critical
- **D - Incorrect:** Historical analysis assists but doesn't substantively inform

Q86: Collaborative Research Cloud Model

Question

Which cloud computing deployment model is MOST appropriate for collaborative research program between universities?

A. Private cloud
B. Community cloud
C. Public cloud
D. Hybrid cloud

Q86: Explanation

Correct Answer: B

A community cloud deployment model is appropriate because it is shared between several enterprises and supports a specific community that has a common mission or interest.

Option Analysis

- **A - Incorrect:** Private cloud is for single enterprise
- **B - Correct:** Community cloud is for shared mission
- **C - Incorrect:** Public cloud is for general public
- **D - Incorrect:** Hybrid is combination

Q87: Control Environment Review

Question

Which line of defense is MOST likely involved when conducting a review of adequacy of control environment?

A. First line of defense
B. Second line of defense
C. Third line of defense
D. Third-party line of defense

Q87: Explanation

Correct Answer: A

A control environment review is a first line of defense activity, where control owners are responsible for adequacy of the control environment.

Option Analysis

- **A - Correct:** First line reviews control environment
- **B - Incorrect:** Second line provides risk-based consultation
- **C - Incorrect:** Third line provides independent attestation
- **D - Incorrect:** Not part of 3LoD model

Q88: Board Concern About Risk Management

Question

Which issue would be of MOST concern to the board when assessing risk management capability?

A. Third line of defense is acting independently
B. Second line is checking and challenging first line
C. Internal audit is preparing risk management strategy
D. Each line of defense is planning independently

Q88: Explanation

Correct Answer: D

Joint planning across the three lines of defense is key to achieving an effective risk management capability. If each line is planning independently, it is an indicator that the lines of defense are not working as expected.

Option Analysis

- **A - Incorrect:** Independence is expected
- **B - Incorrect:** Checking is a role of second line
- **C - Incorrect:** Preparing strategy is expected audit activity
- **D - Correct:** Independent planning indicates dysfunction

Q89: Code of Ethics Adherence

Question

Which MOST effectively supports adherence to enterprise's code of ethics?

- A Ensuring periodic training, evaluation and attestation
- B Performing background checks at hire
- C Providing clear policies and standards
- D Providing continuous awareness throughout the year

Q89: Explanation

Correct Answer: A

Attestation to comply with the enterprise's code of conduct during ethics training ensures that employees have a clear idea of what is expected of them in terms of aligning with the enterprise's ethics code. Training will also provide evaluation to measure employees' understanding.

Option Analysis

- **A - Correct:** Training and attestation ensure understanding
- **B - Incorrect:** Background checks don't check current behavior
- **C - Incorrect:** Policies without attestation don't ensure understanding
- **D - Incorrect:** Continuous training may not be feasible

Q90: Explaining Zero-Day Exploit

Question

Who is responsible for explaining ramifications of new zero-day exploit to senior management?

- A Chief operating officer
- B Chief risk officer
- C Chief information security officer
- D Chief information officer

Q90: Explanation

Correct Answer: B

The chief risk officer is the most senior official accountable for all aspects of risk management across the enterprise, including explaining risk to senior management.

Option Analysis

- **A - Incorrect:** COO operates the enterprise
- **B - Correct:** CRO explains risk to management
- **C - Incorrect:** CISO leads security program but doesn't explain to senior management
- **D - Incorrect:** CIO aligns IT and business

Q91: Information Classification Responsibility

Question

Application of information classification is the responsibility of the:

A. Information security officer
B. Information owner
C. Information systems auditor
D. Information custodian

Q91: Explanation

Correct Answer: B

The information owner determines classification based on the criticality and sensitivity of information.

Option Analysis

- **A - Incorrect:** Security officer has functional responsibility
- **B - Correct:** Information owner classifies data
- **C - Incorrect:** Auditor examines security
- **D - Incorrect:** Custodian preserves CIA

Q92: 3LoD Model Benefit

Question

MOST significant benefit of using three lines of defense model in risk management framework is that it:

A. Ensures ongoing success of risk management initiative
B. Enhances communication between stakeholders
C. Clarifies essential roles of key stakeholders
D. Helps risk owners select appropriate control owners

Q92: Explanation

Correct Answer: C

The three lines of defense model is designed to assign roles related to risk, controls and security while better defining and understanding the relationships between them.

Option Analysis

- **A - Incorrect:** Model supports allocation, doesn't ensure success
- **B - Incorrect:** Not the most significant benefit
- **C - Correct:** Clarifies roles is the main benefit
- **D - Incorrect:** Not the most significant benefit

Q93: First Line of Defense Role

Question

Which risk management role is part of first line of defense?

- A Chief risk officer
- B Risk steering committee
- C Risk owner
- D Board of directors

Q93: Explanation

Correct Answer: C

The first line of defense is operational management, and risk owners are part of operational management.

Option Analysis

- **A - Incorrect:** CRO is second line
- **B - Incorrect:** Steering committee is second line
- **C - Correct:** Risk owner is operational management
- **D - Incorrect:** Board provides direction, not part of 3LoD

Q94: Ultimate Objective of Risk Governance

Question

What is the ULTIMATE objective of risk governance?

- A Benefits realization
- B Risk optimization
- C Resource optimization
- D Value creation

Q94: Explanation

Correct Answer: D

Value creation is the main objective of risk governance and is achieved when the three underlying objectives (benefits realization, risk optimization and resource optimization) are balanced.

Option Analysis

- **A - Incorrect:** Benefits realization is one objective
- **B - Incorrect:** Risk optimization is one objective
- **C - Incorrect:** Resource optimization is one objective
- **D - Correct:** Value creation is ultimate objective

Q95: Second Line of Defense Responsibility

Question

Which activity would be a direct responsibility of the second line of defense?

A. Establish a risk management framework
B. Identify, assess and respond to risk
C. Implement information security controls
D. Test and report control effectiveness

Q95: Explanation

Correct Answer: A

Establishing a risk management framework, providing awareness training, and supervising overall risk management are responsibilities of the second line of defense.

Option Analysis

- **A - Correct:** Framework establishment is second line
- **B - Incorrect:** This is first line operational management
- **C - Incorrect:** Implementation is first line
- **D - Incorrect:** Testing is third line

Q96: Developing Ethical Behavior

Question

Developing and practicing ethical behavior within an enterprise contributes the most to:

A. Determining risk appetite
B. Building risk culture
C. Enhancing risk management
D. Increasing risk tolerance

Q96: Explanation

Correct Answer: B

Practicing professional ethics within an enterprise helps stakeholders in reviewing risk associated with unethical behavior before making decisions. This establishes the risk culture of the enterprise.

Option Analysis

- **A** - **Incorrect:** Ethics doesn't impact appetite
- **B** - **Correct:** Ethics builds risk culture
- **C** - **Incorrect:** Ethics doesn't enhance risk management
- **D** - **Incorrect:** Ethics doesn't impact tolerance

Q97: Most Important Benefit of Professional Ethics

Question

Which is MOST important benefit when stakeholders promote and follow professional ethics?

A. Increases reliability in risk management processes
B. Increases risk management effectiveness within enterprise
C. Improves compliance with regulatory requirements
D. Improves enterprise's reputation and business growth

Q97: Explanation

Correct Answer: B

When stakeholders follow ethical practices, actions and decisions are based on reviewing the results and impact of these actions and decisions. This promotes a risk-based approach to decision-making and enhances overall risk management.

Option Analysis

- **A - Incorrect:** Ethics may reduce some vulnerabilities
- **B - Correct:** Enhances overall risk management
- **C - Incorrect:** Compliance is a result of enhanced risk management
- **D - Incorrect:** Reputation is a secondary benefit

Q98: Proactive Ethics Approach

Question

Which is BEST proactive approach for practicing professional ethics?

- A Develop an ethics policy
- B Implement processes to report unethical behavior
- C Define disciplinary action procedures
- D Provide ethics awareness training

Q98: Explanation

Correct Answer: D

Awareness training is the most proactive approach to improve professional ethics within an enterprise; training will inform employees on the enterprise's code of ethics and ethics policies, and enable employees to make decisions and take appropriate action.

Option Analysis

- **A - Incorrect:** Policy without awareness is ineffective
- **B - Incorrect:** Reporting is reactive
- **C - Incorrect:** Discipline is reactive
- **D - Correct:** Awareness training is proactive

Q99: Critical for 3LoD Effectiveness

Question

Which is MOST critical to ensure three lines of defense work together effectively?

A. Documented disaster recovery plan
B. Automated operational processes
C. Independent external audits
D. Clear, detailed roles and responsibilities

Q99: Explanation

Correct Answer: D

Without clear, detailed job descriptions for employees working in each line of defense, there can be confusion on what is expected at each level, which may hinder the effectiveness of each line of defense.

Option Analysis

- **A - Incorrect:** DR plan doesn't directly affect 3LoD
- **B - Incorrect:** Automation may or may not improve effectiveness
- **C - Incorrect:** Audits uncover issues but don't ensure effectiveness
- **D - Correct:** Clear roles are essential

Q100: IT Plan Driver

Question

Which choice should drive the IT plan?

A. Strategic planning and business requirements
B. Technology and operational procedures
C. Compliance with laws and regulations
D. Project plans and stakeholder requirements

Q100: Explanation

Correct Answer: A

IT exists to support business objectives. Management of enterprise IT should align the IT plan closely with the business.

Option Analysis

- **A - Correct:** Business requirements drive IT plan
- **B - Incorrect:** Technology should not eclipse business strategy
- **C - Incorrect:** Compliance is evaluated like any other risk
- **D - Incorrect:** Project-based approach leads to duplication

Q101: Risk Response Report

Question

A risk response report includes recommendations for:

A. Acceptance
B. Assessment
C. Evaluation
D. Quantification

Q101: Explanation

Correct Answer: A

Acceptance of a risk is an alternative to be considered in the risk response process.

Option Analysis

- **A - Correct:** Acceptance is a risk response option
- **B - Incorrect:** Assessment is completed prior to risk response
- **C - Incorrect:** Evaluation is part of assessment
- **D - Incorrect:** Quantification is an input to risk response

Q102: Reducing to Acceptable Risk

Question

Which is MOST likely to be reduced to achieve acceptable risk?

- A Risk appetite
- B Control risk
- C Residual risk
- D Inherent risk

Q102: Explanation

Correct Answer: C

Residual risk is the remaining risk after management has implemented a risk response. Acceptable risk is achieved when the residual risk is reduced to the levels within the enterprise's risk appetite.

Option Analysis

- **A - Incorrect:** Risk appetite doesn't change with mitigation
- **B - Incorrect:** Control risk is not necessarily related
- **C - Correct:** Residual risk must be reduced to acceptable level
- **D - Incorrect:** Inherent risk cannot be eliminated

Q103: Risk Acceptance Reason

Question

Global financial institution decided not to take further action on a denial-of-service vulnerability. MOST likely reason is:

A. Needed countermeasure is too complicated to deploy
B. Sufficient safeguards are in place
C. Likelihood of risk occurring is unknown
D. Cost of countermeasure outweighs value of asset and potential loss

Q103: Explanation

Correct Answer: D

An enterprise may decide to accept a specific risk because the protection would cost more than the potential loss.

Option Analysis

- **A** - **Incorrect:** Complicated doesn't mean cost prohibitive
- **B** - **Incorrect:** Safeguards must match risk impact
- **C** - **Incorrect:** Frequency can't be predicted but not reason for acceptance
- **D** - **Correct:** Cost-benefit analysis justifies acceptance

Q104: Cost-Benefit Analysis Component

Question

Which is MOST relevant to include in a cost-benefit analysis of two-factor authentication system?

A. Approved budget of project
B. Frequency of incidents
C. Annual loss expectancy of security incidents
D. Total cost of ownership

Q104: Explanation

Correct Answer: D

Total cost of ownership is the most relevant piece of information to be included in the cost-benefit analysis because it establishes a cost baseline that must be considered for the full life cycle of the control.

Option Analysis

- **A** - **Incorrect:** Budget may not reflect actual cost
- **B** - **Incorrect:** Indirect relationship to benefit
- **C** - **Incorrect:** Indirect relationship
- **D** - **Correct:** TCO establishes full life cycle cost baseline

Q105: Outsourcing Contract Priority

Question

Which is MOST important part of any outsourcing contract?

- A Right to audit outsourcing provider
- B Provisions to assess compliance of provider
- C Procedures for incident notification
- D Requirements to encrypt hosted data

Q105: Explanation

Correct Answer: B

If a contract contains no provision to monitor and hold a supplier accountable for security, then the outsourcing enterprise cannot ensure compliance or proper handling of its data.

Option Analysis

- **A** - **Incorrect:** Provider may provide proof of compliance
- **B** - **Correct:** Compliance assessment is essential
- **C** - **Incorrect:** Contract usually doesn't contain procedure details
- **D** - **Incorrect:** Encryption may not be required for all data

Q106: Cloud Provider Greatest Risk

Question

Which poses GREATEST risk to enterprise that recently engaged services of cloud provider?

A. Cloud provider's facility is in same vicinity as subscriber
B. Service level agreement is ambiguous
C. References from other customers were not obtained
D. Auditing vendor requires dependence on third-party audit firm

Q106: Explanation

Correct Answer: B

If the service level agreement is ambiguous, it will be difficult to determine whether the provider complies.

Option Analysis

- **A** - **Incorrect:** No direct impact if continuity plan is adequate
- **B** - **Correct:** Ambiguous SLA makes compliance verification difficult
- **C** - **Incorrect:** References are important but can't assure delivery
- **D** - **Incorrect:** Inability to audit is less than desirable but allowed under SSAE 18

Q107: Risk Cannot Be Sufficiently Mitigated

Question

When risk cannot be sufficiently mitigated through controls, which option BEST protects enterprise from potential financial impact?

- A Insuring against the risk
- B Updating IT risk registry
- C Improving staff training in risk area
- D Outsourcing related process to third party

Q107: Explanation

Correct Answer: A

An insurance policy can compensate the enterprise monetarily for the impact of the risk by transferring the risk to the insurance company.

Option Analysis

- **A - Correct:** Insurance transfers financial risk
- **B - Incorrect:** Updating registry doesn't change risk
- **C - Incorrect:** Training may reduce but not completely mitigate
- **D - Incorrect:** Outsourcing doesn't necessarily remove risk

Q108: Cost Exceeds Benefit

Question

Cost to mitigate risk is much greater than benefit. BEST risk response is:

A. Treated
B. Terminated
C. Accepted
D. Transferred

Q108: Explanation

Correct Answer: C

When the cost of control is more than the cost of the potential impact, the risk should be accepted.

Option Analysis

- **A - Incorrect:** Treatment costs more than benefit
- **B - Incorrect:** Risk can be avoided, not terminated
- **C - Correct:** Acceptance is appropriate when cost ¿ benefit
- **D - Incorrect:** Transfer is limited benefit if cost ¿ benefit

Q109: Risk Scenario for Service Disruptions

Question

Senior management at data center provider wants to improve continuity of operations. Which risk management activity will MOST benefit?

A. Develop key risk indicators
B. Determine risk and control ownership
C. Update risk register
D. Develop IT risk scenarios

Q109: Explanation

Correct Answer: D

The relationship between IT risk scenarios and business impact must be established to understand the effects of possible adverse events on enterprise objectives.

Option Analysis

- **A - Incorrect:** KRIs help understand potential changes
- **B - Incorrect:** Ownership is important but scenarios identify circumstances
- **C - Incorrect:** Scenarios specifically correlate adverse events to business outcomes
- **D - Correct:** Risk scenarios connect IT risk to business impact

Q110: Reciprocal Agreement

Question

Critical IT equipment delivered several days late due to flooding. Reciprocal agreement exists with another company for replacement. This is risk:

A. Transfer
B. Avoidance
C. Acceptance
D. Mitigation

Q110: Explanation

Correct Answer: D

Risk mitigation attempts to reduce the impact when a risk event occurs. Making plans such as a reciprocal arrangement with another company reduces the consequence of the risk event.

Option Analysis

- **A - Incorrect:** Not transferred using insurance or other strategy
- **B - Incorrect:** Arranging standby is mitigation, not avoidance
- **C - Incorrect:** Risk is not accepted
- **D - Correct:** Reciprocal arrangement reduces impact

Q111: Selecting Risk Response

Question

Which BEST helps enterprise select an appropriate risk response?

A. Analysis of change in risk environment
B. Analysis of risk that can be transferred
C. Analysis of likelihood and impact of risk scenarios
D. Analysis of control costs and benefits

Q111: Explanation

Correct Answer: D

An analysis of costs and benefits for controls helps an enterprise understand if it can mitigate the risk to an acceptable level.

Option Analysis

- **A - Incorrect:** Change in environment doesn't provide cost/benefit
- **B - Incorrect:** Risk can never be eliminated
- **C - Incorrect:** Likelihood/impact help establish risk level, not response
- **D - Correct:** Cost-benefit analysis helps select response

Q112: Optimal Return on Security Investment

Question

Which leads to BEST optimal return on security investment?

- A Deploying maximum security protection across all assets
- B Focusing on most important information assets and determining their protection
- C Deploying minimum protection across all assets
- D Investing only after major security incident

Q112: Explanation

Correct Answer: B

To optimize return on security investment, the primary focus should be identifying the important information assets and protecting them appropriately to optimize investment (i.e., important information assets get more protection than less important or critical assets).

Option Analysis

- **A - Incorrect:** Overprotects less critical assets
- **B - Correct:** Focus on important assets optimizes investment
- **C - Incorrect:** Compromises security of critical assets
- **D - Incorrect:** Reactive approach may severely compromise operations

Q113: Reducing Impact of Compromised Admin Account

Question

Which control can reduce potential impact of malicious hacker who gains access to administrator account?

- A Multifactor authentication
- B Audit logging
- C Least privilege
- D Password policy

Q113: Explanation

Correct Answer: C

Least privilege can reduce the impact of a compromised account within the scope of its intended use and limit impact to the enterprise as a whole, without restricting the performance of employees in administrative roles.

Option Analysis

- **A - Incorrect:** Control has already been bypassed
- **B - Incorrect:** Audit logging is lagging indicator
- **C - Correct:** Least privilege limits scope of damage
- **D - Incorrect:** Password changes may not be frequent enough

Q114: Critical for Effective Risk Management

Question

Which is critical to risk practitioner for effective risk management program?

A. Risk response strategy
B. Risk register content
C. Risk profile content
D. Risk owners and accountability

Q114: Explanation

Correct Answer: D

The identification of risk owners is critical because risk owners must make informed and cost-effective business decisions regarding appropriate controls to mitigate their owned risk. Risk response strategy, risk registers and risk profiles are tools that require ownership by users who apply them proactively and with accountability.

Option Analysis

- **A - Incorrect:** Strategy provides options but owners are critical
- **B - Incorrect:** Register identifies risk but owners are critical
- **C - Incorrect:** Profile describes risk but owners are critical
- **D - Correct:** Risk owners are essential for accountability

Q115: Anti-Malware Cost Exceeds Loss Expectancy

Question

Cost of anti-malware exceeds loss expectancy of malware threats. What is MOST viable risk response?

A. Risk elimination
B. Risk acceptance
C. Risk transfer
D. Risk mitigation

Q115: Explanation

Correct Answer: B

When the cost of a risk response exceeds the loss expectancy, the most viable risk response is risk acceptance.

Option Analysis

- **A - Incorrect:** Risk elimination is not possible
- **B - Correct:** Acceptance when cost exceeds expected loss
- **C - Incorrect:** Transfer also based on cost-benefit analysis
- **D - Incorrect:** Mitigation also based on cost-benefit analysis

Q116: Risk Avoidance Example

Question

Which is BEST example of risk avoidance behavior?

A. Taking no action against the risk
B. Outsourcing the related process
C. Insuring against a specific event
D. Exiting the process that gives rise to risk

Q116: Explanation

Correct Answer: D

Avoidance means exiting the activities or conditions that give rise to risk.

Option Analysis

- **A - Incorrect:** This is acceptance
- **B - Incorrect:** This is transfer/sharing
- **C - Incorrect:** This is transfer/sharing
- **D - Correct:** Exiting process is avoidance

Q117: Critical Dependencies in Risk Treatment

Question

Which would ensure that critical dependencies are addressed in the risk treatment plan?

A. Implement risk treatment strategy for all possible risk

B. Verify accomplishment of business objectives through top-down process review

C. Treat each risk independently

D. Verify accomplishment through bottom-up process review

Q117: Explanation

Correct Answer: B

Development of an overall risk treatment strategy should be a top-down process, driven jointly by the need to achieve business objectives and to apply economically feasible constraints while controlling uncertainty within the enterprise risk appetite.

Option Analysis

- **A - Incorrect:** Not economically feasible for all risk
- **B - Correct:** Top-down ensures business objectives drive treatment
- **C - Incorrect:** Independent treatment creates gaps
- **D - Incorrect:** Bottom-up doesn't ensure dependencies addressed

Q118: Anti-Malware as Risk Response

Question

CISO recommends controls like anti-malware to protect IS. Which risk handling approach is this?

- A Risk transference
- B Risk mitigation
- C Risk acceptance
- D Risk avoidance

Q118: Explanation

Correct Answer: B

By implementing controls, the company is trying to reduce the risk to an acceptable level, thereby mitigating risk.

Option Analysis

- **A - Incorrect:** Transfer involves another entity
- **B - Correct:** Controls reduce risk to acceptable level
- **C - Incorrect:** Acceptance is taking no action
- **D - Incorrect:** Avoidance stops activity causing risk

Q119: Outsourcing Risk Mitigation

Question

Which practice BEST mitigates risk associated with outsourcing a business function?

- A Performing audits to verify compliance with contract
- B Requiring all vendor staff to complete annual awareness training
- C Retaining copies of all sensitive data on internal systems
- D Reviewing financial records of vendor to verify financial soundness

Q119: Explanation

Correct Answer: A

When an outsourcing relationship is established, the risk of noncompliance with the agreement must be met through review, monitoring and enforcement of the contract terms. Therefore, conducting regular audits to verify that the vendor is compliant with contract requirements is an important practice.

Option Analysis

- **A - Correct:** Audits ensure contract compliance
- **B - Incorrect:** Training doesn't provide same level of mitigation
- **C - Incorrect:** Duplicating data increases liability
- **D - Incorrect:** Financial review is important but not best practice

Q120: Risk Transfer Best Addressed

Question

Which is BEST addressed by transferring risk?

A. Antiquated fire suppression system in computer room
B. Threat of disgruntled employee sabotage
C. Threat of disgruntled employee theft
D. Building located in 100-year flood plain

Q120: Explanation

Correct Answer: D

Purchasing an insurance policy transfers the risk of a flood. Risk transfer is the process of assigning risk to another entity, usually through the purchase of an insurance policy or through outsourcing the service.

Option Analysis

- **A - Incorrect:** Should update fire suppression system
- **B - Incorrect:** Not readily transferable
- **C - Incorrect:** Not readily transferable
- **D - Correct:** Flood risk can be transferred through insurance

Q121: Finalizing Risk Treatment Plan

Question

Which would BEST help finalize the risk treatment plan?

A. Vulnerability analysis
B. Impact analysis
C. Cost-benefit analysis
D. SWOT analysis

Q121: Explanation

Correct Answer: C

A cost-benefit analysis helps determine if the benefit of a control outweighs the cost of implementing the control.

Option Analysis

- **A - Incorrect:** Vulnerability analysis identifies risk to treat
- **B - Incorrect:** Impact analysis is part of risk assessment
- **C - Correct:** Cost-benefit helps evaluate treatment options
- **D - Incorrect:** SWOT results must be translated into risk terms

Q122: Risk Treatment Plan Greatest Benefit

Question

GREATEST benefit of implementing a risk treatment plan is:

- A To reduce impact and likelihood of risk occurrence
- B To identify unmitigated risk that can be transferred
- C To exploit risk to test organizational preparedness
- D To enhance overall risk appetite

Q122: Explanation

Correct Answer: A

Implementing the risk treatment plan reduces the negative impact and likelihood of a risk occurrence.

Option Analysis

- **A - Correct:** Reduces impact and likelihood
- **B - Incorrect:** Transfer is not the only option
- **C - Incorrect:** Exploiting risk creates more risk
- **D - Incorrect:** Risk appetite is established, not influenced

Q123: Validating Patching Program

Question

What is BEST method to validate effectiveness of enterprise's patching program?

A. Conduct penetration testing
B. Conduct risk identification initiative
C. Carry out vulnerability scans
D. Review requests for change

Q123: Explanation

Correct Answer: C

Performing vulnerability scans will enable the IT risk practitioner to determine if patches are being installed on a timely basis.

Option Analysis

- **A - Incorrect:** Penetration testing could elevate risk
- **B - Incorrect:** Risk identification identifies new risk, not patching effectiveness
- **C - Correct:** Vulnerability scans show patch status
- **D - Incorrect:** RFCs don't mean patches are applied

Q124: Designing IS Controls

Question

Which is MOST important factor when designing information systems controls in complex environment?

A. Development methodologies
B. Scalability of solution
C. Technical platform interfaces
D. Stakeholder requirements

Q124: Explanation

Correct Answer: D

The most important factor when designing information systems controls is their ability to advance the interests of the business by addressing stakeholder requirements.

Option Analysis

- **A - Incorrect:** Important but not as important as stakeholder requirements
- **B - Incorrect:** Important but not as important
- **C - Incorrect:** Important but not as important
- **D - Correct:** Stakeholder requirements drive control design

Q125: EFT System Testing

Question

Risk practitioner would MOST benefit from a test that:

A. Identifies introduction of potential new gaps in security
B. Verifies adequate system recovery in case of failure
C. Ensures system performs to expectation
D. Ensures system can support volume of transactions

Q125: Explanation

Correct Answer: A

The security of an electronic funds transfer (EFT) system would be of the most interest to a risk practitioner. Testing should identify the introduction of potential new gaps in information security.

Option Analysis

- **A - Correct:** Security gaps are most important to risk practitioner
- **B - Incorrect:** Recovery is not as high priority
- **C - Incorrect:** Performance is not as high priority
- **D - Incorrect:** Stress testing is not as high priority

Q126: Creating KRIs for Reporting

Question

What is BEST approach for creating KRIs for quarterly reporting to senior leadership?

A. Survey senior leaders about primary risk concerns

B. Identify list of most common network vulnerabilities

C. Determine which KRIs are used in similar industry

D. Identify enterprise risk appetite and metrics of current risk

Q126: Explanation

Correct Answer: D

Key risk indicators (KRIs) are measurable and quantifiable indicators of risk to assist in the monitoring and appropriate risk treatment proactively.

Option Analysis

- **A - Incorrect:** Feedback may be subjective and immeasurable
- **B - Incorrect:** Vulnerabilities lack likelihood and impact
- **C - Incorrect:** KRIs should be based on enterprise's risk appetite
- **D - Correct:** Risk appetite and current risk measures drive KRIs

Q127: Gauging Risk for Stakeholders

Question

Which can serve to gauge risk that may trigger stakeholder concern?

- A Indicators with approved thresholds
- B Approved status report of completed milestones
- C List of controls to be implemented by supplier
- D Number of findings in external audit reports

Q127: Explanation

Correct Answer: A

Indicators with approved thresholds demonstrate the acceptable risk levels stakeholders are willing to tolerate, and any risk above those approved levels will likely trigger stakeholder concern.

Option Analysis

- **A - Correct:** Thresholds show acceptable risk levels
- **B - Incorrect:** Status report shows completed milestones only
- **C - Incorrect:** Controls list is requirements, not thresholds
- **D - Incorrect:** Audit findings are not indicators of tolerance

Q128: Ensuring Access Revocation

Question

Which control within user provision process BEST ensures revocation of system access for contractors when no longer required?

A. Log all account usage and send to managers
B. Establish predetermined, automatic expiration dates
C. Ensure each user signs security acknowledgment
D. Require managers to email security when user leaves

Q128: Explanation

Correct Answer: B

Predetermined expiration dates are the most effective means of removing systems access for temporary users.

Option Analysis

- **A - Incorrect:** Logging is detective, not as effective as preventive
- **B - Correct:** Automatic expiration is most effective
- **C - Incorrect:** Signing acknowledgment has little effect
- **D - Incorrect:** Managers often don't submit termination notices promptly

Q129: Presenting Risk Profile to Board

Question

Which BEST helps while presenting current risk profile to executive management and board?

A. Risk response dashboard
B. Emerging risk report
C. Risk register dashboard
D. Key risk indicators report

Q129: Explanation

Correct Answer: C

A risk register dashboard would provide a comprehensive overview of the risk profile of the enterprise.

Option Analysis

- **A - Incorrect:** Risk response is one component only
- **B - Incorrect:** Emerging risk report would not be complete
- **C - Correct:** Risk register dashboard provides comprehensive view
- **D - Incorrect:** KRI report is only one component

Q130: Main Reason for KCI Trends

Question

Which is MAIN reason senior management monitors and analyzes trends in key control indicators?

A. Provides feedback on overall control environment
B. Helps in identifying redundant controls
C. Proactively identifies impacts to risk profile
D. Helps determine if additional controls required

Q130: Explanation

Correct Answer: C

The primary objective of key control indicators (KCIs) is to ensure that controls actually mitigate risk at an effective level. Analysis of KCI trends provides information on the overall effectiveness of controls and provides management information on the status of risk management.

Option Analysis

- **A - Incorrect:** Control environment is operations responsibility
- **B - Incorrect:** Redundancy is design/operations responsibility
- **C - Correct:** KCIs proactively identify risk profile impacts
- **D - Incorrect:** Determining additional controls is operations responsibility

Q131: Risk Treatment Plans Purpose

Question

Risk treatment plans are necessary to describe how the:

A. Identified risk is further analyzed
B. Chosen treatment options will be implemented
C. Accepted risk is treated
D. Risk indicators will monitor the risk

Q131: Explanation

Correct Answer: B

A risk treatment plan includes the plan of action for the chosen treatment, how it will be implemented, who will implement it, key dates and resource requirements.

Option Analysis

- **A - Incorrect:** Treatment plan doesn't further analyze risk
- **B - Correct:** Plan describes implementation
- **C - Incorrect:** Accepted risk doesn't need treatment plan
- **D - Incorrect:** Risk indicators are not part of treatment plan

Q132: Cost-Benefit Analysis Timing

Question

In risk management process, cost-benefit analysis is MAINLY performed:

A. As part of initial risk assessment
B. As part of risk-response planning
C. During information asset valuation
D. When insurance is calculated for risk transfer

Q132: Explanation

Correct Answer: B

In risk response, a range of controls that can mitigate risk will be identified; however, a cost-benefit analysis in this process will help identify the right controls to address the risk at acceptable levels within the budget.

Option Analysis

- **A - Incorrect:** Performed not just once but every time controls needed
- **B - Correct:** During risk-response planning
- **C - Incorrect:** Value determined by business importance
- **D - Incorrect:** Not the stage where cost-benefit is performed

Q133: Insufficient Risk Treatment Resources

Question

In event available resources for risk treatment are not sufficient, the risk treatment plan should:

A. Define priorities across all treatments to assist in resource allocation
B. Recommend postponing treatment until resources available
C. Recommend reassessing risk treatment options
D. Suggest increasing priority to ensure resource availability

Q133: Explanation

Correct Answer: A

When the available resources for treating the risk are not sufficient, the risk treatment plan should include prioritization of the risk so resources can be properly allocated.

Option Analysis

- **A - Correct:** Prioritization drives resource allocation
- **B - Incorrect:** May not be most appropriate option
- **C - Incorrect:** Prioritization already determined
- **D - Incorrect:** Doesn't consider other priorities

Q134: Backup/Restore Control Classification

Question

System backup and restore procedures can BEST be classified as:

A. Technical controls
B. Detective controls
C. Corrective controls
D. Deterrent controls

Q134: Explanation

Correct Answer: C

Corrective controls remediate the impact from negative events. If a system suffers harm so extensive that processing cannot continue, backup restore procedures enable that system to be recovered.

Option Analysis

- **A - Incorrect:** Technical controls are hardware/software safeguards
- **B - Incorrect:** Detective controls identify violations
- **C - Correct:** Backup/restore corrects impact
- **D - Incorrect:** Deterrent controls discourage compromise

Q135: Policy Exception Process Reason

Question

PRIMARY reason for initiating a policy-exception process is:

A. Risk is justified by the benefit
B. Policy compliance is difficult to enforce
C. Operations are too busy to comply
D. Users may initially be inconvenienced

Q135: Explanation

Correct Answer: A

Exceptions to policies are warranted if the benefits outweigh the costs of policy compliance; however, the enterprise needs to assess both the tangible and intangible risk and evaluate both in the context of existing risk.

Option Analysis

- **A - Correct:** Benefit justifies exception
- **B - Incorrect:** Difficulty doesn't justify exception
- **C - Incorrect:** Lack of resources doesn't justify exception
- **D - Incorrect:** Inconvenience doesn't justify exception

Q136: Measuring Operational Control Effectiveness

Question

Which would BEST measure effectiveness of operational controls?

A. Control matrix
B. Key performance indicator
C. Statement of applicability
D. Key control indicator

Q136: Explanation

Correct Answer: D

Key control indicators, also referred to as control effectiveness indicators, are metrics that provide information on the degree to which a control is working.

Option Analysis

- **A - Incorrect:** Control matrix is analysis tool
- **B - Incorrect:** KPIs don't measure control effectiveness
- **C - Incorrect:** SOA is ISO 27001 specific
- **D - Correct:** KCIs measure control effectiveness

Q137: Security Technology Selection Basis

Question

Security technologies should be selected PRIMARILY on basis of:

A. Evaluation in security publications
B. Compliance with industry standards
C. Ability to mitigate risk to organizational objectives
D. Cost compared to IT budget

Q137: Explanation

Correct Answer: C

The most fundamental criterion for selecting security technology is the capacity to reduce risk for organizational objectives.

Option Analysis

- **A - Incorrect:** Publication evaluation is valuable but secondary
- **B - Incorrect:** Industry compliance is secondary
- **C - Correct:** Risk mitigation is primary
- **D - Incorrect:** Cost is an important but secondary consideration

Q138: Black Box Penetration Test Preparation

Question

Which should be in place before a black box penetration test begins?

A. Clearly stated definition of scope
B. Previous test results
C. Proper communication and awareness training
D. Incident response plan

Q138: Explanation

Correct Answer: A

A clearly stated definition of scope ensures a proper understanding of risk and success criteria.

Option Analysis

- **A - Correct:** Scope definition is essential
- **B - Incorrect:** Previous results may help define scope
- **C - Incorrect:** Communication/training not necessary
- **D - Incorrect:** IR plan not necessary

Q139: Securing Network Against External Attack

Question

Which is BEST way to ensure corporate network is adequately secured against external attack?

A. Use intrusion detection system
B. Establish minimum security baselines
C. Implement vendor recommended settings
D. Perform periodic penetration testing

Q139: Explanation

Correct Answer: D

Penetration testing is the best way to ensure that perimeter security is adequate.

Option Analysis

- **A - Incorrect:** IDS detects but doesn't confirm security
- **B - Incorrect:** Baselines are beneficial but not sufficient
- **C - Incorrect:** Vendor settings are beneficial but not sufficient
- **D - Correct:** Penetration testing provides highest assurance

Q140: Establishing Key Control Indicators

Question

Which is PRIMARILY defined before establishing key control indicators?

A. Desired capacity
B. Desired risk threshold
C. Desired tolerances
D. Desired risk appetite

Q140: Explanation

Correct Answer: C

The goal of KCIs is to track performance of control actions relative to tolerances, providing insight into the ongoing adequacy of a given control in keeping risk within acceptable levels; for this reason, KCIs are sometimes called control effectiveness indicators. Therefore, tolerances would need to be defined before a KCI could be established.

Option Analysis

- **A** - **Incorrect:** Capacity management is separate
- **B** - **Incorrect:** KCIs are not related to risk thresholds
- **C** - **Correct:** Tolerances must be defined first
- **D** - **Incorrect:** KCIs are not related to risk appetite

Q141: Substantive Test for Tape Inventory

Question

A substantive test to verify tape library inventory records are accurate involves:

- A Determining whether bar code readers are installed
- B Conducting physical count of tape inventory
- C Checking whether receipts and issues are accurately recorded
- D Determining whether movement of tapes is authorized

Q141: Explanation

Correct Answer: B

A substantive test involves gathering evidence to evaluate the integrity of individual transactions, data or other information. Conducting a physical count of the tape inventory is a substantive test.

Option Analysis

- **A - Incorrect:** Testing bar code readers is compliance test
- **B - Correct:** Physical count is substantive test
- **C - Incorrect:** Accuracy check is compliance test
- **D - Incorrect:** Authorization check is compliance test

Q142: Ensuring Vulnerability Mitigation

Question

Which BEST ensures appropriate mitigation occurs on identified IS vulnerabilities?

- A Presenting root cause analysis to management
- B Implementing software to input action points
- C Incorporating findings into annual report
- D Assigning action plans with deadlines to responsible personnel

Q142: Explanation

Correct Answer: D

Assigning mitigation to personnel establishes responsibility for its completion within the deadline.

Option Analysis

- **A - Incorrect:** Management awareness doesn't ensure action
- **B - Incorrect:** Software helps monitor, doesn't ensure completion
- **C - Incorrect:** Reporting to shareholders doesn't ensure completion
- **D - Correct:** Assigning to personnel ensures accountability

Q143: Audit Report Supplementary Controls

Question

Which is BEST action if audit report recommends supplemental controls for uncritical functions?

- A Appoint project lead to start implementation
- B Eliminate risk by purchasing risk insurance
- C Request IT department implement all supplemental controls
- D Request cost-benefit analysis to determine business need

Q143: Explanation

Correct Answer: D

A cost-benefit analysis may help determine if supplemental controls are needed, making this the best action to take. This is to ensure the cost of the control does not exceed the impact from the risk being realized.

Option Analysis

- **A - Incorrect:** Need must be justified first
- **B - Incorrect:** Insurance decision comes after cost-benefit
- **C - Incorrect:** Need must be justified first
- **D - Correct:** Cost-benefit determines business need

Q144: Peer Review Enablement

Question

Which BEST enables a peer review of an enterprise's risk management process?

- A Balanced scorecard
- B Industry survey
- C Capability maturity model
- D Framework

Q144: Explanation

Correct Answer: C

A capability maturity model describes essential elements and criteria for effective processes for one or more disciplines. It also outlines an evolutionary improvement path from ad hoc, immature processes to disciplined, mature processes with improved quality and effectiveness.

Option Analysis

- **A - Incorrect:** Balanced scorecard is performance measurement
- **B - Incorrect:** Survey results are aggregated
- **C - Correct:** Maturity model enables peer comparison
- **D - Incorrect:** Framework defines concepts, not maturity

Q145: Risk Treatment Plan Information

Question

Which is MOST important information to include in risk treatment plan with resolution and date for completion?

- A Responsible personnel
- B Mitigating factors
- C Likelihood of occurrence
- D Cost of completion

Q145: Explanation

Correct Answer: A

Risk response activities must be assigned to a responsible person or group; if this assignment is not included, it will be unclear who will implement the countermeasure.

Option Analysis

- **A - Correct:** Responsible personnel is essential
- **B - Incorrect:** Can be included but not as important
- **C - Incorrect:** Can be included but not as important
- **D - Incorrect:** Cost is optional

Q146: Ensuring Acceptable Risk Level

Question

Which BEST ensures identified risk remains at acceptable level?

- A Reviewing controls periodically, according to risk treatment plan
- B Listing each risk as separate entry in risk register
- C Creating separate risk register for every department
- D Maintaining KRI for assets in risk register

Q146: Explanation

Correct Answer: A

Controls deployed according to the risk treatment plan should provide the desired results, because the risk treatment plan is based on management's acceptance of residual risk and management's approval of deployment steps in the plan.

Option Analysis

- **A - Correct:** Periodic review ensures continued effectiveness
- **B - Incorrect:** Register in itself doesn't ensure management
- **C - Incorrect:** Separate registers don't ensure management
- **D - Incorrect:** KRI in register doesn't ensure management

Q147: Risk Response Increasing Liability

Question

Which risk response option is MOST likely to increase liability of enterprise?

A. Risk acceptance
B. Risk reduction
C. Risk transfer
D. Risk avoidance

Q147: Explanation

Correct Answer: A

An enterprise may choose to accept risk without knowing the correct level of risk that is being accepted; this may result in accusations of negligence.

Option Analysis

- **A - Correct:** Acceptance without proper assessment may be negligence
- **B - Incorrect:** Reduction attempts to reduce risk
- **C - Incorrect:** Transfer allocates risk to another party
- **D - Incorrect:** Avoidance terminates process

Q148: Reason Not to Reduce Risk

Question

Which is BEST reason for enterprise to decide not to reduce an identified risk?

- A No regulatory requirement
- B There are mitigating controls in place
- C Cost of mitigation exceeds the risk
- D Budget for mitigation is limited

Q148: Explanation

Correct Answer: C

Enterprises will accept the risk when the cost of mitigation exceeds the risk.

Option Analysis

- **A - Incorrect:** Regulatory isn't the only factor
- **B - Incorrect:** Residual risk may still be above acceptable levels
- **C - Correct:** Cost-benefit justifies acceptance
- **D - Incorrect:** May reduce even when budget exceeded

Q149: Outsourcing IT Activities

Question

Enterprise addresses risk associated with IT project by outsourcing part of IT activities to third party with specialized skill set. This is:

A. Risk transfer
B. Risk avoidance
C. Risk acceptance
D. Risk mitigation

Q149: Explanation

Correct Answer: D

When specific activities are outsourced to an entity with a specialized skill set, the inherent risk of the activity is reduced. The outsourcing process works as a control in this case.

Option Analysis

- **A - Incorrect:** Risk remains with enterprise
- **B - Incorrect:** Not avoidance
- **C - Incorrect:** Not acceptance
- **D - Correct:** Outsourcing reduces inherent risk

Q150: Cost-Effective Risk Response

Question

Which BEST facilitates cost-effective risk response?

A. Prioritizing and addressing risk according to risk management strategy
B. Mitigating risk on basis of likelihood and impact
C. Performing countermeasure analysis for each control
D. Selecting controls that are at zero or near-zero costs

Q150: Explanation

Correct Answer: A

Prioritizing and addressing risk in line with the risk treatment strategy balances the costs and benefits of managing the IT risk.

Option Analysis

- **A - Correct:** Prioritization balances costs and benefits
- **B - Incorrect:** Multiple occurrences with similar products
- **C - Incorrect:** May not be a countermeasure for every control
- **D - Incorrect:** Zero-cost controls may not be effective

Q151: Enterprise Architecture Purpose

Question

PRIMARY reason for developing an enterprise security architecture is to:

A. Align security strategies among functional areas and external entities
B. Build barrier between IT systems and outside world
C. Foster understanding of technologies and their interactions
D. Protect enterprise from external threats and monitor proactively

Q151: Explanation

Correct Answer: A

The enterprise security architecture must align strategies and objectives of diverse functional areas within the enterprise, optimize the flow of information within an enterprise, and support all required communication with external partners, customers and suppliers.

Option Analysis

- **A - Correct:** Alignment is primary purpose
- **B - Incorrect:** Building barrier may interfere with business
- **C - Incorrect:** Architecture documents interactions in relation to business
- **D - Incorrect:** Architecture establishes blueprint, doesn't directly protect

Q152: Approving Risk Appetite

Question

Who is responsible for approving enterprise's risk appetite and risk tolerance related to information security?

A. Business unit manager
B. Information security officer
C. Senior management
D. Risk manager

Q152: Explanation

Correct Answer: C

Senior management determines enterprise risk appetite and risk tolerance.

Option Analysis

- **A - Incorrect:** BU manager doesn't determine appetite
- **B - Incorrect:** ISO doesn't determine appetite
- **C - Correct:** Senior management approves appetite/tolerance
- **D - Incorrect:** Risk manager doesn't determine appetite

Q153: Influencing Risk Management Approach

Question

Which would be MOST influential in determining an enterprise's approach to risk management?

A. Recent audit report findings
B. Chief information security officer approval
C. Key performance indicators
D. Enterprise policies

Q153: Explanation

Correct Answer: D

Enterprise policies state the guidance for risk management.

Option Analysis

- **A - Incorrect:** Audit findings focus on specific areas
- **B - Incorrect:** Approach cannot be determined only from CISO
- **C - Incorrect:** KPIs monitor attainment, don't determine approach
- **D - Correct:** Enterprise policies guide risk management

Q154: New Data Protection Regulation

Question

What information should risk practitioner gather to BEST ensure compliance with new data protection regulation?

- A List of controls to implement
- B Gaps associated with existing controls
- C Risk scenarios with potential impact on compliance
- D Enterprise's risk appetite

Q154: Explanation

Correct Answer: C

Risk scenarios should indicate potential effects of noncompliance with the new regulation and guide management in evaluating whether the cost of compliance outweighs the cost of noncompliance and aligns with the enterprise's risk tolerance.

Option Analysis

- **A - Incorrect:** Control list comes after business decision
- **B - Incorrect:** Control gaps useful after business decision
- **C - Correct:** Risk scenarios inform compliance decision
- **D - Incorrect:** Risk appetite suggests scenarios

Q155: Supply Chain Risk

Question

Which will BEST assist risk practitioner when addressing risk within supply chain life cycle?

- A Understanding supplier's organizational systems
- B Understanding business case in support of life cycle
- C Understanding relevant jurisdictional legal requirements
- D Understanding enterprise's risk approach toward supply chain

Q155: Explanation

Correct Answer: C

Identification and understanding of the legal requirements relevant to the supply chain will assist the risk practitioner to identify, assess and monitor risk on an ongoing basis.

Option Analysis

- **A - Incorrect:** Important but not best
- **B - Incorrect:** Business case created prior to agreement
- **C - Correct:** Legal requirements are essential across regions
- **D - Incorrect:** Important but legal requirements are more important

Q156: First Management Priority

Question

To ensure risk program effectively mitigates risk, which should FIRST be addressed by management?

A. Risk findings
B. Incomplete new hire checks
C. Low rate of risk management training completion
D. Blame culture

Q156: Explanation

Correct Answer: D

A blame culture should be addressed and remedied as soon as possible. It hinders effective risk mitigation because it defeats accountability.

Option Analysis

- **A - Incorrect:** Addressing findings is harder in blame culture
- **B - Incorrect:** Consideration but not as important
- **C - Incorrect:** Consideration but not as important
- **D - Correct:** Blame culture defeats accountability

Q157: Key Element of Risk Culture

Question

Which is a KEY element of risk culture?

A. Tolerance
B. Policies
C. Behavior
D. Controls

Q157: Explanation

Correct Answer: C

Behavior toward taking risk, negative outcomes, and policy compliance are all elements of an enterprise's risk culture.

Option Analysis

- **A - Incorrect:** Tolerance is one element of behavior
- **B - Incorrect:** Policies are influenced by culture
- **C - Correct:** Behavior determines risk culture
- **D - Incorrect:** Controls are influenced by culture

Q158: Accountable for Risk Governance Strategy

Question

Who is accountable for overall enterprise strategy for risk governance?

- A Senior management
- B Business unit management
- C Chief risk officer
- D Board of directors

Q158: Explanation

Correct Answer: D

The board of directors is accountable for the overall enterprise risk governance strategy as it states the enterprise strategy.

Option Analysis

- **A - Incorrect:** Strategy comes from board, not senior management
- **B - Incorrect:** Strategy comes from board
- **C - Incorrect:** Strategy comes from board
- **D - Correct:** Board is accountable for strategy

Q159: Primary Goal of IT Risk Management

Question

What is PRIMARY goal of enterprise's IT risk management process?

- (A) Protect IT assets and environment
- (B) Protect enterprise and its ability to perform mission
- (C) Report on status of IT risk register
- (D) Ensure risk is identified and properly managed

Q159: Explanation

Correct Answer: B

The primary goal of an enterprise's risk management process is to protect the enterprise and its ability to perform its mission.

Option Analysis

- **A - Incorrect:** Should protect enterprise, not just IT assets
- **B - Correct:** Protect enterprise and mission
- **C - Incorrect:** Reporting is one tool, not the goal
- **D - Incorrect:** Identification is one component

Q160: Risk Management Programs Goal

Question

Risk management programs are designed to reduce risk to:

A. Point where benefit exceeds expense
B. Level too small to be significant
C. Rate of return equals cost of capital
D. Level enterprise is willing to accept

Q160: Explanation

Correct Answer: D

Risk should be reduced to a level that an enterprise (i.e., management) is willing to accept; therefore, risk management primarily seeks to facilitate business judgment and support enterprise business goals.

Option Analysis

- **A - Incorrect:** Depends on risk appetite
- **B - Incorrect:** Not practical and cost prohibitive
- **C - Incorrect:** Not practical to calculate for each action
- **D - Correct:** Acceptable level determined by management

Q161: Enterprise Security Policy Control Type

Question

An enterprise security policy is an example of which control?

A. Operational control
B. Management control
C. Technical control
D. Corrective control

Q161: Explanation

Correct Answer: B

There are two control methods: technical and nontechnical. Enterprise security policies are nontechnical management controls.

Option Analysis

- **A - Incorrect:** Manufacturing procedures are operational
- **B - Correct:** Policy is management control
- **C - Incorrect:** Encryption/IDS are technical
- **D - Incorrect:** Corrective controls respond to incidents

Q162: Most Essential for Risk Program

Question

Which is MOST essential for a risk management program to be effective?

- A New risk detection
- B Sound risk baseline
- C Accurate risk reporting
- D Flexible security budget

Q162: Explanation

Correct Answer: A

Without identifying new risk, other measures will succeed only for a limited period.

Option Analysis

- **A - Correct:** New risk detection is essential
- **B - Incorrect:** Baseline is essential but detection is more essential
- **C - Incorrect:** Reporting is essential but detection is more essential
- **D - Incorrect:** Flexible budget is not available to most enterprises

Q163: Most Important for Risk Mitigation

Question

Which is MOST important when mitigating or managing risk?

- A Vulnerability assessment results
- B Business impact analysis
- C Risk appetite and tolerance levels
- D Security controls framework

Q163: Explanation

Correct Answer: C

The risk tolerance level (along with risk appetite) determines what kind of risk response an enterprise selects, and it needs to be defined in order for an enterprise to appropriately address risk.

Option Analysis

- **A - Incorrect:** Provides view of control environment
- **B - Incorrect:** Concerned with prioritizing, not how to mitigate
- **C - Correct:** Tolerance/appetite determine response
- **D - Incorrect:** Framework describes what, not actionable recommendations

Q164: Reporting IT Control Status

Question

Which is MOST important component when reporting status of IT control environment to management?

- A Amendments to risk register
- B Lessons learned from loss events
- C Technical details on vulnerabilities
- D Risk profile of enterprise

Q164: Explanation

Correct Answer: D

The risk profile of the enterprise is the most important component because it provides the overall portfolio of identified risk to which the enterprise is exposed. This is most important for management to know.

Option Analysis

- **A - Incorrect:** Amendments are important but not as important
- **B - Incorrect:** Lessons learned are not sufficient
- **C - Incorrect:** Technical details are not expected at management level
- **D - Correct:** Risk profile is most important

Q165: Risk Scenarios in Assessments

Question

Which uses risk scenarios when estimating likelihood and impact of significant risk?

A. IT audit
B. Security gap analysis
C. Threat and vulnerability assessment
D. IT security assessment

Q165: Explanation

Correct Answer: C

A threat and vulnerability assessment typically evaluates all elements of a business process for threats and vulnerabilities and identifies the likelihood of occurrence and the business impact if the threats were realized.

Option Analysis

- **A - Incorrect:** IT audit uses technical evaluation
- **B - Incorrect:** Gap analysis doesn't use risk scenarios
- **C - Correct:** Threat/vulnerability assessment uses risk scenarios
- **D - Incorrect:** Security assessment uses technical evaluation

Q166: Deviation from Policy

Question

Enterprise wants to quickly implement technical solution deviating from policy. Risk practitioner should:

- A Recommend against implementation
- B Recommend revision of current policy
- C Conduct risk assessment and allow/disallow based on outcome
- D Recommend risk assessment and implementation only if residual risk accepted

Q166: Explanation

Correct Answer: D

A risk assessment should be conducted to clarify the risk whenever the enterprise's policies cannot be followed. The solution should be implemented only if the related risk is formally accepted by the enterprise.

Option Analysis

- **A - Incorrect:** Business decisions driven by cost/benefit
- **B - Incorrect:** Should not be triggered by single request
- **C - Incorrect:** Management makes final decision
- **D - Correct:** Risk assessment and formal acceptance required

Q167: Qualitative Risk Analysis

Question

Which will produce comprehensive results when performing a qualitative risk analysis?

A. Vulnerability assessment
B. Scenarios with threats and impacts
C. Value of information assets
D. Estimated productivity losses

Q167: Explanation

Correct Answer: B

Using a list of possible scenarios with threats and impacts will better frame the range of risk and facilitate a more informed discussion and decision.

Option Analysis

- **A - Incorrect:** One-sided view unless linked to scenarios
- **B - Correct:** Scenarios frame risk range
- **C - Incorrect:** Value without threats/impacts is insufficient
- **D - Incorrect:** Productivity losses are insufficient

Q168: Removing Risk from Register

Question

Risk may be removed from risk register when risk:

A. Has been eliminated
B. Is transferred to vendor
C. Threshold is exceeded
D. Is no longer relevant

Q168: Explanation

Correct Answer: D

If a risk is relevant, it will be listed in the risk register. Once the risk is no longer relevant, it may be removed.

Option Analysis

- **A - Incorrect:** Risk cannot be eliminated
- **B - Incorrect:** Enterprise still accountable for risk
- **C - Incorrect:** If threshold exceeded, risk remains relevant
- **D - Correct:** No longer relevant means can be removed

Q169: Accurate Risk Register Maintenance

Question

Which is BEST way to ensure accurate risk register is maintained over time?

- A Monitor KRIs and record findings
- B Publish risk register centrally with workflow features
- C Distribute register to business process owners for review
- D Use audit personnel to perform regular audits

Q169: Explanation

Correct Answer: B

Centrally publishing the risk register and enabling periodic polling of risk assessors through workflow features will ensure accuracy of content. A knowledge management platform with workflow and polling features will automate the process of maintaining the risk register.

Option Analysis

- **A - Incorrect:** Only provides insights to known risk
- **B - Correct:** Workflow automation ensures accuracy
- **C - Incorrect:** Business owners may not be unbiased
- **D - Incorrect:** Audit personnel may not have business knowledge

Q170: Adding Emerging Risk

Question

An emerging risk should be added to risk register by risk practitioner when:

- A Impact can be quantified
- B Probability of occurrence is high
- C Competitor has added risk
- D Activity that triggers risk initiates

Q170: Explanation

Correct Answer: D

Risk identification usually starts when planning an activity, and risk identified at planning needs to be added to the risk register to ensure effective risk management.

Option Analysis

- **A - Incorrect:** Quantification is important but not decision factor
- **B - Incorrect:** High impact alone not the only criterion
- **C - Incorrect:** Industry benchmark shouldn't be used
- **D - Correct:** Risk identified at planning should be added

Q171: Primary Objective of Risk Management

Question

Which is PRIMARY objective of a risk management program?

- A Maintain residual risk at acceptable level
- B Implement preventive controls for every threat
- C Remove all identified risk
- D Reduce inherent risk to zero

Q171: Explanation

Correct Answer: A

Ensuring that all residual risk is maintained at a level acceptable to the business is the objective of a risk management program.

Option Analysis

- **A - Correct:** Maintain residual risk at acceptable level
- **B - Incorrect:** Not the objective of risk management
- **C - Incorrect:** Not intended to remove every identified risk
- **D - Incorrect:** Inherent risk is always greater than zero

Q172: Risk Assessment Techniques Use

Question

Risk assessment techniques should be used by risk practitioner to:

A. Maximize return on investment
B. Provide documentation for auditors
C. Justify selection of risk mitigation strategies
D. Quantify risk that would otherwise be subjective

Q172: Explanation

Correct Answer: C

A risk practitioner should use risk assessment techniques to justify and implement a risk mitigation strategy as efficiently as possible.

Option Analysis

- **A - Incorrect:** Maximizing ROI is not part of risk assessment
- **B - Incorrect:** Doesn't focus on auditors as primary recipients
- **C - Correct:** Justifies risk mitigation strategies
- **D - Incorrect:** Risk assessment is high-level; analysis can be quantitative or qualitative

Q173: New Printer Risk

Question

Procurement employee notices new printer models keep copy of all printed documents on internal hard disk. Employee should:

A. Proceed with order and configure printers to auto-wipe data

B. Notify security manager to conduct risk assessment

C. Seek vendor without built-in hard disks

D. Procure with hard disks and notify staff to wipe when decommissioning

Q173: Explanation

Correct Answer: B

Risk assessment is most appropriate because it yields risk mitigation techniques that are appropriate for enterprise risk context and appetite.

Option Analysis

- **A - Incorrect:** Not appropriate without prior risk assessment
- **B - Correct:** Risk assessment identifies appropriate controls
- **C - Incorrect:** Focusing solely on risk ignores opportunity
- **D - Incorrect:** Notifying staff is not sufficient control

Q174: Risk Assessment Recurrence

Question

Risk assessments should be repeated at regular intervals because:

A. Omissions in earlier assessments can be addressed

B. Periodic assessments allow various methodologies

C. Business threats are constantly changing

D. They help raise risk awareness among staff

Q174: Explanation

Correct Answer: C

As business objectives and methods change, the nature and relevance of threats also change.

Option Analysis

- **A - Incorrect:** Omissions don't justify regular reassessments
- **B - Incorrect:** Same methodologies should be used
- **C - Correct:** Threats constantly change
- **D - Incorrect:** Better ways to raise awareness exist

Q175: Assessing IS Risk

Question

Assessing information systems risk is BEST achieved by:

A. Using enterprise's past actual loss experience
B. Reviewing published loss statistics
C. Evaluating threats associated with existing IS assets
D. Reviewing IS control weaknesses in audit reports

Q175: Explanation

Correct Answer: C

To assess IT risk, threats and vulnerabilities need to be evaluated using qualitative or quantitative risk assessment approaches.

Option Analysis

- **A - Incorrect:** Doesn't address realistic risk scenarios
- **B - Incorrect:** Doesn't address enterprise-specific scenarios
- **C - Correct:** Evaluating threats is fundamental
- **D - Incorrect:** Control weaknesses alone are not useful

Q176: Lack of Adequate Controls

Question

A lack of adequate controls represents:

- A. A vulnerability
- B. An impact
- C. An asset
- D. A threat

Q176: Explanation

Correct Answer: A

Lack of adequate controls represents a vulnerability, exposing sensitive information and data to the risk of malicious damage, attack, or unauthorized access.

Option Analysis

- **A - Correct:** Vulnerability = lack of controls
- **B - Incorrect:** Impact is financial loss measure
- **C - Incorrect:** Assets have tangible/intangible value
- **D - Incorrect:** Threat is potential cause

Q177: Security Breach at Another Entity

Question

Enterprise learns of security breach at another entity using similar network technology. MOST important action is:

A. Assess likelihood of incident occurring
B. Discontinue use of vulnerable technology
C. Report to senior management that enterprise is not affected
D. Remind staff no similar breaches have taken place

Q177: Explanation

Correct Answer: A

The likelihood of a similar incident occurring at the risk practitioner's enterprise should be assessed first, based on available information.

Option Analysis

- **A - Correct:** Assess likelihood first
- **B - Incorrect:** Discontinuation may not be required
- **C - Incorrect:** Premature report
- **D - Incorrect:** Cannot be certain

Q178: Comprehensive Risk Assessment Trigger

Question

MOST likely trigger for conducting comprehensive risk assessment is detection of changes in:

A. Asset inventory
B. Asset classification levels
C. Business environment
D. Information security policies

Q178: Explanation

Correct Answer: C

Changes in the business environment, including new threats, vulnerabilities, or changes to information asset deployment, will trigger comprehensive periodic risk assessment.

Option Analysis

- **A - Incorrect:** Ongoing process, doesn't trigger
- **B - Incorrect:** Classification changes don't trigger
- **C - Correct:** Business environment changes trigger assessment
- **D - Incorrect:** Policy changes don't trigger assessment

Q179: Anonymous Risk Identification

Question

Which is BEST risk identification technique to support enterprise that allows employees to identify risk anonymously?

A. Delphi technique
B. Isolated pilot groups
C. SWOT analysis
D. Root cause analysis

Q179: Explanation

Correct Answer: A

With the Delphi technique, polling or information gathering is done either anonymously or privately between the interviewer and interviewee.

Option Analysis

- **A - Correct:** Delphi uses anonymous polling
- **B - Incorrect:** Participants don't identify anonymously
- **C - Incorrect:** Participants don't identify anonymously
- **D - Incorrect:** Participants don't identify anonymously

Q180: Risk Register Information

Question

Which BEST describes information needed for each risk in a risk register?

- A Date, description, impact, probability, risk score, mitigation action, owner
- B Date, description, risk score, cost to remediate, communication plan, owner
- C Date, description, impact, cost to remediate, owner
- D Various activities leading to risk management planning

Q180: Explanation

Correct Answer: A

Information required for each risk in a risk register includes date, description, impact, probability, risk score, mitigation action and owner.

Option Analysis

- **A - Correct:** All required elements included
- **B - Incorrect:** Missing impact, probability, mitigation action
- **C - Incorrect:** Missing probability, risk score, mitigation action
- **D - Incorrect:** Risk register results from planning, not vice versa

Q181: Business Impact Analysis Advantage

Question

GREATEST advantage in performing a business impact analysis is that it:

A. Does not have to be updated
B. Promotes continuity awareness in enterprise
C. Requires only qualitative estimates
D. Eliminates need for risk analysis

Q181: Explanation

Correct Answer: B

A BIA raises enterprise-wide awareness of risk to business recovery and continuity.

Option Analysis

- **A - Incorrect:** Should be updated periodically
- **B - Correct:** Promotes continuity awareness
- **C - Incorrect:** Should use both qualitative and quantitative
- **D - Incorrect:** Cannot eliminate risk analysis

Q182: Risk Register Primary Advantage

Question

PRIMARY advantage of creating and updating a risk register is to:

A. Ensure inventory of identified risk is maintained
B. Record all risk scenarios considered
C. Collect similar data on all risk
D. Run reports based on various risk scenarios

Q182: Explanation

Correct Answer: A

Once assets and risk are identified, the risk register is used as an inventory of that risk. The risk register can accelerate risk decision-making and establish accountability for specific risk.

Option Analysis

- **A - Correct:** Maintaining inventory is primary advantage
- **B - Incorrect:** Recording is good practice but inventory is primary
- **C - Incorrect:** Data collection is benefit but inventory is primary
- **D - Incorrect:** Running reports is a benefit but not primary

Q183: Measuring Risk Management Development

Question

Which BEST assists in measuring existing level of development of risk management processes against desired state?

A. Capability maturity model
B. Risk management audit reports
C. Balanced scorecard
D. Enterprise security architecture

Q183: Explanation

Correct Answer: A

The capability maturity model grades processes on a scale of 0 to 5, based on their maturity, and is commonly used by entities to measure their existing state and then to determine the desired one.

Option Analysis

- **A - Correct:** Maturity model measures current vs desired
- **B - Incorrect:** Offers limited view
- **C - Incorrect:** Measures implementation of strategy
- **D - Incorrect:** Explains security architecture

Q184: Assessing Business Risk

Question

Which is MOST effective in assessing business risk?

A. Use case analysis
B. Business case analysis
C. Risk scenarios
D. Risk plan

Q184: Explanation

Correct Answer: C

Risk scenarios are the most effective technique in assessing business risk. Scenarios help determine the likelihood and impact of an identified risk.

Option Analysis

- **A - Incorrect:** Identifies business requirements
- **B - Incorrect:** Part of project charter
- **C - Correct:** Scenarios determine likelihood and impact
- **D - Incorrect:** Output of risk assessment

Q185: Risk Register Preparation

Question

Preparation of a risk register begins in which risk management process?

- A Risk response planning
- B Risk monitoring and control
- C Risk management planning
- D Risk identification

Q185: Explanation

Correct Answer: D

The risk register details all identified risk, including description, category, cause, probability of occurring, impact on objectives, proposed responses, owners and current status. The primary outputs of risk identification are the initial entries into the risk register.

Option Analysis

- **A - Incorrect:** Responses determined and included in register
- **B - Incorrect:** New risk identified triggers updates
- **C - Incorrect:** Describes how risk management will be performed
- **D - Correct:** Risk identification creates initial entries

Q186: BIA Primary Use

Question

A business impact analysis is PRIMARILY used to:

- (A) Estimate resources to resume normal operations
- (B) Evaluate impact of disruption on ability to operate over time
- (C) Calculate likelihood and impact of known threats
- (D) Evaluate high-level business requirements

Q186: Explanation

Correct Answer: B

A BIA is primarily intended to evaluate the impact of disruption over time to an enterprise's ability to operate. It determines the urgency of each business activity. Key deliverables include recovery time objectives and recovery point objectives.

Option Analysis

- **A - Incorrect:** This is business continuity planning
- **B - Correct:** Evaluates impact over time
- **C - Incorrect:** Calculated during risk analysis
- **D - Incorrect:** Defined during early SDLC phases

Q187: Risk Scenarios Enable Assessment

Question

Risk scenarios enable the risk assessment process because they:

A. Cover a wide range of potential risk

B. Minimize need for quantitative risk analysis

C. Segregate IT risk from business risk

D. Help estimate frequency and impact of risk

Q187: Explanation

Correct Answer: D

While risk scenarios may address a wide range of risk, risk scenarios help to estimate the frequency and impact of risk—two key elements of the risk assessment process. These elements aid subsequent steps in risk management by making risk relevant to business process owners.

Option Analysis

- **A - Incorrect:** Not always the result
- **B - Incorrect:** Don't necessarily minimize quantitative analysis
- **C - Incorrect:** Can be applied to both
- **D - Correct:** Help estimate frequency and impact

Q188: Best Help for Risk Scenarios

Question

Which information in risk register BEST helps in developing proper risk scenarios?

- A List of potential threats to assets
- B List of residual risk on individual assets
- C List of accepted risk
- D List of security incidents

Q188: Explanation

Correct Answer: A

Identifying potential threats to business assets will help isolate vulnerabilities and associated risk, all of which contribute to developing proper risk scenarios.

Option Analysis

- **A - Correct:** Potential threats help develop scenarios
- **B - Incorrect:** Doesn't help develop scenarios
- **C - Incorrect:** Generally small subset
- **D - Incorrect:** Previous incidents may inspire scenarios but not best approach

Q189: Identifying Control Deficiencies

Question

Which BEST helps identify information systems control deficiencies?

- A Gap analysis
- B Current IT risk profile
- C IT controls framework
- D Countermeasure analysis

Q189: Explanation

Correct Answer: A

Controls are deployed to achieve control objectives based on risk assessments and business requirements. The gap between desired control objectives and actual control design and operational effectiveness identifies control deficiencies in information systems.

Option Analysis

- **A - Correct:** Gap analysis identifies deficiencies
- **B - Incorrect:** Doesn't expose gap to desired state
- **C - Incorrect:** Generic document with no current state info
- **D - Incorrect:** Only helps identify countermeasure deficiencies

Q190: Assessing Application Server Performance

Question

When assessing performance of critical application server, MOST reliable results may be obtained from:

A. Activation of native database auditing
B. Documentation of performance objectives
C. Continuous monitoring
D. Documentation of security modules

Q190: Explanation

Correct Answer: C

With continuous monitoring it is possible to track key performance metrics and also possible to address critical issues with minimum impact.

Option Analysis

- **A - Incorrect:** Database logs don't provide performance info
- **B - Incorrect:** Documentation is important but doesn't provide performance info
- **C - Correct:** Continuous monitoring tracks performance
- **D - Incorrect:** Security modules don't provide performance info

Q191: Greatest Risk When Updating Register

Question

Which presents GREATEST risk when updating the risk register?

A. Updates carried out jointly with other functions
B. Updates carried out following incidents
C. Updates carried out annually
D. Updates subject to CISO approval

Q191: Explanation

Correct Answer: C

Updating the risk register only annually means the risk register does not reflect the true status of IT risk in the enterprise.

Option Analysis

- **A - Incorrect:** May be managed by multiple functions
- **B - Incorrect:** This presents a risk but not greatest
- **C - Correct:** Annual updates don't reflect true status
- **D - Incorrect:** Problematic but not as great as annual updates

Q192: IT Risk Measurement

Question

IT risk is measured by its:

A. Level of damage to IT systems
B. Impact on business operations
C. Cost of countermeasures
D. Annual loss expectancy

Q192: Explanation

Correct Answer: B

IT risk includes information and communication technology risk but is primarily measured by its impact on the business. IT risk is the business risk associated with the use, ownership, operation, involvement, influence and adoption of IT within an enterprise.

Option Analysis

- **A - Incorrect:** IT damage alone is not comprehensive
- **B - Correct:** Impact on business is primary
- **C - Incorrect:** Cost/benefit is risk response, not assessment
- **D - Incorrect:** ALE must be used with qualitative measures

Q193: Quantitative Risk Analysis

Question

Deriving likelihood and impact of risk scenarios through statistical methods is BEST described as:

A. Quantitative risk analysis
B. Risk scenario analysis
C. Qualitative risk analysis
D. Probabilistic risk assessment

Q193: Explanation

Correct Answer: A

Quantitative risk analysis derives the probability and impact of risk scenarios from statistical methods and data.

Option Analysis

- **A - Correct:** Uses statistical methods
- **B - Incorrect:** Includes several methods
- **C - Incorrect:** Uses non-quantitative measures
- **D - Incorrect:** Applied to complex engineered technology

Q194: Local Mitigation Responsibility

Question

During internal risk assessment, local management proactively mitigated high-level global purchasing process risk. This means:

A. Local management is now responsible for risk
B. Risk owner is corporate chief risk officer
C. Risk owner is local purchasing manager
D. Corporate management remains responsible for risk

Q194: Explanation

Correct Answer: D

Corporate management remains responsible for the risk, even when the risk response is executed at a lower organizational level.

Option Analysis

- **A - Incorrect:** Corporate management remains responsible
- **B - Incorrect:** CRO is responsible for program, not purchasing risk
- **C - Incorrect:** Risk owner is global purchasing manager
- **D - Correct:** Corporate management remains responsible

Q195: Estimating Likelihood of Events

Question

Which BEST estimates likelihood of significant events affecting enterprise?

A. Threat analysis
B. Cost-benefit analysis
C. Scenario analysis
D. Countermeasure analysis

Q195: Explanation

Correct Answer: C

Scenario analysis, along with vulnerability analysis, best determines whether a particular risk is relevant to the enterprise, and helps estimate the likelihood that significant events will affect the enterprise.

Option Analysis

- **A - Incorrect:** Doesn't provide sufficient info
- **B - Incorrect:** Used in selecting controls
- **C - Correct:** Scenario analysis estimates likelihood
- **D - Incorrect:** Assesses controls during attacks

Q196: Improving Risk Decision-Making

Question

Which BEST improves decision-making related to risk?

- A Maintaining documented risk register of all possible risk
- B Risk awareness training in line with risk culture
- C Maintaining updated security policies and procedures
- D Allocating accountability of risk to department as a whole

Q196: Explanation

Correct Answer: A

Maintaining a documented risk register improves decision-making related to risk response because a risk register captures the population of relevant risk scenarios and provides a basis for prioritization of risk responses.

Option Analysis

- **A - Correct:** Register captures and prioritizes risk
- **B - Incorrect:** Training enhances accountability but less useful for emerging threats
- **C - Incorrect:** Policies don't necessarily improve decisions
- **D - Incorrect:** Department accountability dilutes ownership

Q197: Independent Risk Management Review

Question

PRIMARY reason to have risk management process reviewed by independent risk management professional is to:

A. Validate cost-effective solutions
B. Validate control weaknesses
C. Assess validity of end-to-end process
D. Assess whether risk profile and factors are properly defined

Q197: Explanation

Correct Answer: C

The independent risk professional will be unbiased to review the risk management process end to end. The independent reviewer will not have any involvement in any stage of the risk management process and will be unaffected by all internal factors.

Option Analysis

- **A - Incorrect:** Internal teams can provide cost-effective solutions
- **B - Incorrect:** Internal team can find weaknesses
- **C - Correct:** Independent review of end-to-end process
- **D - Incorrect:** Risk profile is properly defined when assessment is correct

Q198: Reviewing IT Risk Analysis Results

Question

Which is BEST suited for review of IT risk analysis results before sending to management?

A. Internal audit review
B. Peer review
C. Compliance review
D. Risk policy review

Q198: Explanation

Correct Answer: B

It is effective, efficient and good practice to perform a peer review of IT risk analysis results before sending them to management.

Option Analysis

- **A - Incorrect:** Internal audit is independent assurance
- **B - Correct:** Peer review is good practice
- **C - Incorrect:** Compliance reviews measure conformance
- **D - Incorrect:** Policy review may change content but isn't review method

Q199: First Step in Identifying IT Risk

Question

FIRST step in identifying and assessing IT risk is to:

- A Confirm risk tolerance level
- B Identify threats and vulnerabilities
- C Gather information on current and future environment
- D Review past incident reports

Q199: Explanation

Correct Answer: C

The first step in any risk assessment is to gather information about the current state and pending internal and external changes to the enterprise's environment (scope, technology, incidents, modifications, etc.).

Option Analysis

- **A - Incorrect:** Tolerance informs response, not identification
- **B - Incorrect:** Must be supplemented by environmental changes
- **C - Correct:** Gather environmental information first
- **D - Incorrect:** Past incidents are one input but not adequate

Q200: Risk Scenarios Creation Basis

Question

Risk scenarios should be created PRIMARILY based on:

- A Input from senior management
- B Previous security incidents
- C Threats that the enterprise faces
- D Results of risk analysis

Q200: Explanation

Correct Answer: C

When creating risk scenarios, the most important factor to consider is the likelihood of threats or threat actions occurring due to the risk.

Option Analysis

- **A - Incorrect:** Not as critical as threats
- **B - Incorrect:** Not as critical as threats
- **C - Correct:** Threats are most important
- **D - Incorrect:** Scenarios should input to risk analysis

CRISC Key Takeaways

Essential Concepts from QAE

- Risk identification is the first step
- Risk appetite = willingness to accept risk
- Risk tolerance = acceptable deviation from appetite
- Risk capacity = maximum before existence threatened
- Residual risk = risk remaining after controls
- Three lines of defense: Operations, Oversight, Audit

CRISC Key Takeaways (continued)

More Essential Concepts

- AL E = SLE $\times$ ARO
- SLE = Asset Value $\times$ Exposure Factor
- RPO is backward-looking; RTO is forward-looking
- Risk response: Mitigate, Accept, Transfer, Avoid
- Security policy = management control
- KRIs = early warning signals

Final Advice

Exam Preparation

Remember:

- Understand the *why* behind each concept
- Know control categories (Preventive, Detective, Corrective, Deterrent, Compensating)
- Understand recovery objectives (RPO, RTO, MTD)
- Know risk appetite vs tolerance vs capacity
- Practice scenario-based questions

Good Luck on Your CRISC Exam!